Rapport de veille technologique, technique, réglementaire et normative

Sécurité du système d'information

AéroStar SAS (organisation fictive)

Période : du 24/10/2026 au 31/10/2026
Généré le 31/10/2026 à 15:32 (UTC)
Périmètre : Veille technique et cybersécurité, Veille technologique, Veille réglementaire, Veille normative
Outil : VeilleCyber 1.0.0 — moteur d'analyse regles-1.0

ORGANISATION FICTIVE (cas d'étude) — les éléments de veille présentés ont été réellement collectés.

1. Résumé exécutif

[Fait] Sur la période du 24/10/2026 au 31/10/2026, 1150 éléments ont été collectés automatiquement auprès de 49 sources fonctionnelles. Après exclusion des éléments anciens republiés (395), non pertinents (46) ou écartés par l'analyste (0), 709 éléments entrent dans le périmètre de ce rapport.

Priorité	Nombre d'éléments
Critique	0
Élevée	9
Modérée	133
Faible	564
À qualifier	3

[Analyse] Points d'attention prioritaires (un sujet couvert par plusieurs sources n'est cité qu'une fois) :

- [Élevée] Cisco Secure Firewall Adaptive Security Appliance and Secure Firewall Threat Defense Software Remote Access SSL VPN Tunnel Denial of Service Vulnerability (Cisco — Security Advisories, 2026-10-28) — Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire.
- [Élevée] AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise (Microsoft Security Blog, 2026-10-21) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision.
- [Élevée] CVE-2026-70125 Microsoft Office Outlook Remote Code Execution Vulnerability (Microsoft — Security Update Guide, 2026-10-30) — Vérifier la présence et les versions de Microsoft 365 (Exchange Online, Teams, SharePoint) concernées par l'avis (inventaire, outil de gestion de parc).
- [Élevée] New Cisco firewall zero-day exploited to crash SSL VPN devices (BleepingComputer, 2026-10-29) — Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire.
- [Élevée] Microsoft urges Entra ID admins to migrate users to passkeys (BleepingComputer, 2026-10-28) — Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée.
- [Élevée] Agents are your newest insiders. Security must move at their speed. (Microsoft Security Blog, 2026-10-19) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision.
- [Élevée] Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware (The Hacker News, 2026-10-26) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision.
- [Élevée] nginx-1.30.6 stable and nginx-1.31.7 mainline versions have been released, with fixes for buffer overflow vulnerability when using alias with rewrite (CVE-2026-15176), buffer overflow vulnerability when evaluating string expressions with variables (CVE-2026-93479), request body injection vulnerability in HTTP/3 (CVE-2026-95101), session forgery vulnerability when using TLS session ticket key [...] (nginx — Actualités (correctifs de sécurité), 2026-10-13) — confirmé par 1 autre(s) source(s) : Ubuntu — Security Notices — Vérifier la présence et les versions de Intranet (nginx) concernées par l'avis (inventaire, outil de gestion de parc).

[Analyse] Textes dont l'applicabilité est probable ou indirecte (à confirmer) : RGPD, AirCyber, Part-IS.

[Recommandation] 30 actions sont proposées ou en cours dans le plan d'action (0 critiques, 9 élevées).

[Analyse] 54 éléments de priorité modérée ou plus se rattachent aux scénarios redoutés de l'organisation (détail en section 11).

[Fait] Échéances à venir : Renouvellement de l'assurance cyber conditionné au MFA généralisé et à des sauvegardes testées — courant 2027 (date exacte à préciser) ; Niveau AirCyber Bronze exigé par Nacelia Systems et Garonne Aérostructures (Silver ensuite) — dans 426 jours (~14 mois).

Organisation fictive (cas d'étude) : le contexte, l'inventaire et les chiffres de l'organisation sont inventés ; les éléments de veille, sources et référentiels cités sont réels et ont été réellement collectés.

2. Objectifs et périmètre de la veille

Objectifs : (1) surveiller les menaces, vulnérabilités et innovations technologiques pertinentes ; (2) suivre l'évolution des cadres légaux et des normes applicables ; (3) analyser leurs impacts sur l'organisation ; (4) identifier les obligations à vérifier et les opportunités d'amélioration de la sécurité du SI.

Organisation étudiée

Élément	Valeur déclarée
Nom	AéroStar SAS (organisation fictive)
Secteur	Ingénierie / bureau d'études ; secondaires : Aéronautique et spatial (filière)
Taille	Moyenne entreprise (< 250 salariés et CA ≤ 50 M€) — 120 salariés
Maturité cyber	1 — Initiale (pratiques informelles)
Rôles	Responsable de traitement (RGPD), Fournisseur ou sous-traitant d'entités potentiellement soumises à NIS 2, Dépositaire de données confidentielles de clients (plans, maquettes)
Données traitées	Propriété intellectuelle / secrets d'affaires, Données clients / usagers, Données personnelles (général), Données RH / salariés, Données techniques potentiellement soumises au contrôle export (double usage)
Activités	Bureau d'études aéronautique de rang 2 (créé en 2004) : conception mécanique et calcul de structures de pièces (supports, carénages, éléments de nacelle et d'aménagement cabine); Dossiers de justification et documentation technique pour des équipementiers de rang 1; Échanges quotidiens de fichiers CAO lourds avec les clients (plateforme collaborative de la filière, archives par mail pour un client); Site unique à Blagnac (31) : plateau de bureaux et atelier de maquettes ; télétravail 2 jours par semaine pour les ingénieurs
Technologies inventoriées	14
Exigences identifiées	RGPD (legale, identifiee); Contrats clients (NDA, plans d'assurance sécurité) (contractuelle, identifiee); AirCyber (BoostAeroSpace) (contractuelle, identifiee); EN 9100:2018 (normative, identifiee); ISO/IEC 27001 (normative, cible); NIS 2 (legale, a_confirmer); Contrôle des biens à double usage (legale, a_confirmer); Assurance cyber (contractuelle, identifiee)
Thèmes technologiques	Zero Trust, IAM, MFA et gestion des identités, Sécurité de la messagerie et lutte contre l'hameçonnage, Sauvegarde, restauration et continuité d'activité, SIEM, EDR, XDR, détection et réponse aux incidents, Nouvelles méthodes de détection, de prévention et de remédiation, Sécurité du cloud, des conteneurs et de la chaîne logicielle, Intelligence artificielle et IA générative

Contraintes et constats de départ

- **Contrainte :** Budget : PME à marges serrées ; toute mesure doit être chiffrée et justifiée par un gain (garder un client, baisser la prime d'assurance, obtenir une aide Cyber Boost). Enveloppe sécurité de 180 k€ sur 18 mois, hors aide Cyber Boost
- **Contrainte :** Ressources : 4 personnes à l'IT, aucune dédiée à la cybersécurité ; le responsable IT est aussi référent sécurité (pas de RSSI)
- **Contrainte :** Métier : licences CAO coûteuses liées à un serveur de licences sur site ; stations CAO puissantes, lourdes à remplacer
- **Contrainte :** Infogérant sans astreinte : pas d'intervention réseau ni pare-feu hors heures ouvrées
- **Contrainte :** Continuité visée : RTO 24 h et RPO 4 h pour le serveur du BE, RTO 4 h pour l'AD ; une journée d'arrêt du BE coûte environ 55 k€ plus les pénalités
- **Constat :** Réseau à plat (serveurs, postes, imprimantes et Wi-Fi invités sur le même réseau)
- **Constat :** Pas de MFA sur site, comptes administrateurs partagés (dont celui de l'infogérant), mots de passe par défaut dans l'AD
- **Constat :** Sauvegardes sur un NAS dans la même salle, jamais restaurées ; pas de PRA
- **Constat :** Aucune supervision : journaux non centralisés ; inventaire non à jour, serveurs mis à jour « quand on a le temps »
- **Constat :** Points uniques de défaillance : serveur de fichiers du BE, serveur de licences CAO, lien Internet unique, infogérant, responsable IT
- **Constat :** Incident de mars 2026 : compte Microsoft 365 d'un ingénieur compromis par un faux lien de partage, utilisé deux jours pour envoyer du phishing aux clients

Besoins de sécurité

Besoin	Critère	Exigence cible
Protéger les plans et maquettes clients	Confidentialité	Très forte
Livrer à la date contractuelle (moins de 4 h d'arrêt du BE en journée)	Disponibilité	Forte

Besoin	Critère	Exigence cible
Garantir que le plan livré est le bon (gestion de configuration)	Intégrité	Très forte
Prouver qui a modifié quoi (EN 9100, audits clients)	Traçabilité	Forte

Scénarios redoutés suivis par la veille

Scénario	Description
Rançongiciel via compte volé et compromission de l'AD	Un rançongiciel entre par un compte volé, prend le contrôle de l'AD et chiffre le serveur du bureau d'études à trois semaines d'un jalon client, avec menace de publier les plans.
Compromission de messagerie Microsoft 365 par hameçonnage	Répétition de l'incident de mars 2026 : vol de session ou d'identifiants Microsoft 365, envoi d'hameçonnage aux clients, accès aux échanges de plans.
Fuite ou vol de plans et maquettes clients	Exfiltration de données de conception confiées par les clients (espionnage industriel, prestataire ou indépendant compromis, envoi par mail non maîtrisé).

Parties prenantes et attentes de sécurité

Partie prenante	Attentes
Nacelia Systems, Garonne Aérostructures, Occitane Cabin Interiors (clients de rang 1, fictifs)	Confidentialité, plateforme d'échange sécurisée, AirCyber Bronze fin 2027, notification de tout incident sous 24 h
BoostAeroSpace / GIFAS (Cyber Boost)	Évaluation AirCyber Bronze, Silver ou Gold ; accompagnement et financement de la montée en maturité
Occitanie Numérique Services (infogérant, fictif)	Accès à distance aux serveurs avec un compte administrateur partagé ; pas d'astreinte
Assureur cyber (fictif)	MFA généralisé et sauvegardes testées au renouvellement 2027
CNIL	Notification sous 72 h d'une violation de données personnelles
ANSSI, CERT-FR, Cybermalveillance.gouv.fr	Référentiels, alertes, assistance ; signalement des incidents significatifs
Organisme certificateur EN 9100	Maîtrise et traçabilité de la documentation (audit annuel)

Hypothèses de travail

- **[Hypothèse] :** Organisation FICTIVE (cas d'étude) : les éléments de veille sont réellement collectés, mais le contexte, l'inventaire et les chiffres de l'organisation sont inventés.
- **[Hypothèse] :** Marque ou modèle non précisé pour : Pare-feu et VPN SSL (géré par l'infogérant), NAS de sauvegarde (salle serveur). La détection repose sur des mots-clés génériques : toute vulnérabilité d'un produit de ce type est à vérifier auprès du gestionnaire.
- **[Hypothèse] :** Versions non renseignées pour certaines technologies : la correspondance porte sur le produit, pas sur la version affectée (vérification manuelle nécessaire).

Périmètre du rapport : Veille technique et cybersécurité, Veille technologique, Veille réglementaire, Veille normative.

3. Méthodologie

- **Collecte :** interrogation automatique de flux RSS/Atom et d'interfaces publiques autorisées (CISA KEV, ISO Open Data, API NVD, FIRST EPSS), à une fréquence propre à chaque source, avec respect de robots.txt, requêtes conditionnelles et limitation de débit. Dates de publication et de collecte conservées séparément.
- **Déduplication :** URL canonique (suppression des paramètres de suivi) puis empreinte du contenu (titre + résumé normalisés).
- **Classification :** règles explicites (mots-clés FR/EN, type et catégorie de la source) en huit catégories ; un article peut relever de plusieurs catégories.
- **Enrichissement :** scores CVSS issus du NVD, exploitation active issue du catalogue CISA KEV, probabilité EPSS (FIRST). Aucune valeur n'est estimée.
- **Pertinence :** rapprochement avec l'inventaire technique, les thèmes surveillés et l'applicabilité des textes au profil de l'organisation.
- **Priorisation :** score additif explicable (gravité, exploitation, présence et exposition dans le parc, criticité, urgence, importance réglementaire, ancienneté) ; niveau « Critique » réservé aux technologies

du parc avec gravité ou exploitation vérifiée.
- **Restitution :** fiche par élément, plan d'action et ce rapport ; chaque information est reliée à son URL d'origine (annexes).
- **Fraîcheur :** les éléments publiés plus de 30 jours avant le début de la période sont exclus des résultats (395 éléments).

[Fait] Exécutions de collecte sur la période : 2 (dont 2 réussies, 0 partielles, 0 en échec).

4. Justification des outils utilisés

Outil	Usage	Justification
Python 3	Langage de l'application	Écosystème mature pour la collecte, l'analyse et la génération de documents.
feedparser	Lecture RSS/Atom	Tolère les flux mal formés ; standard de fait.
httpx	Requêtes HTTP	Délais, flux de réponse et redirections contrôlés (protection SSRF).
SQLite	Stockage	Base locale sans serveur, transactionnelle, suffisante pour une veille d'organisation.
Streamlit	Interface web	Tableau de bord local en français, rapide à déployer.
APScheduler	Planification	Collecte et rapports périodiques ; service système possible.
ReportLab	Export PDF	Génération PDF sans dépendance externe.
API NVD, CISA KEV, FIRST EPSS	Enrichissement	Sources de référence publiques pour CVSS, exploitation et probabilité.
IA (facultative)	Résumés en français	Désactivée par défaut ; contenus traités comme données non fiables ; n'influence pas la priorité.

5. Catalogue des sources et justification

Veille technique et cybersécurité

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
BleepingComputer	Presse spécialisée / Moyenne	2 h	Fonctionnelle	19	Actualité rapide sur les rançongiciels, incidents et vulnérabilités ; à recouper avec une source primaire.
CERT-FR — Alertes de sécurité	Source officielle / Élevée	1 h	Fonctionnelle	4	Centre gouvernemental de veille, d'alerte et de réponse aux attaques informatiques (ANSSI). Les alertes signalent des vulnérabilités activement exploitées ou critiques nécessitant une action rapide.
CERT-FR — Avis de sécurité	Source officielle / Élevée	1 h	Fonctionnelle	53	Avis décrivant les vulnérabilités publiées par les éditeurs, les produits affectés et les correctifs. Source de référence francophone pour la gestion des correctifs.
CERT-FR — Bulletins d'actualité	Source officielle / Élevée	12 h	Fonctionnelle	5	Bulletins hebdomadaires synthétisant les vulnérabilités significatives et les recommandations associées.
CERT-FR — Menaces et incidents	Source officielle / Élevée	12 h	Fonctionnelle	3	Rapports de menace (modes opératoires, rançongiciels, campagnes) produits par l'ANSSI.
CISA — Actualités	Source officielle / Élevée	24 h	Fonctionnelle	3	Annonces de la CISA (stratégies, guides conjoints, campagnes).
CISA — Cybersecurity Advisories	Source officielle / Élevée	3 h	Fonctionnelle	31	Avis techniques (dont systèmes industriels) et alertes conjointes avec les agences partenaires.
CISA — Known Exploited Vulnerabilities (KEV)	Source officielle / Élevée	6 h	Fonctionnelle	37	Catalogue officiel des vulnérabilités dont l'exploitation active est confirmée par la CISA. Utilisé pour vérifier le critère « exploitation active » de la priorisation.
Cisco Talos Intelligence	Recherche / laboratoire / Moyenne	12 h	Fonctionnelle	16	Recherche sur les menaces et vulnérabilités ; source éditeur.

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
Cisco — Security Advisories	Éditeur / fournisseur / Élevée	12 h	Fonctionnelle	43	Avis de sécurité officiels Cisco (réseau, sécurité, collaboration).
Cybermalveillance.gouv.fr — Actualités	Source officielle / Élevée	12 h	Fonctionnelle	5	Alertes sur les campagnes d'hameçonnage et d'escroquerie ; utile pour la sensibilisation des utilisateurs.
Dassault Systèmes — Avis de sécurité (Trust Center)	Éditeur / fournisseur / Élevée	168 h	Bloquée / non collectable	0	Éditeur des outils métier critiques du bureau d'études (CATIA V5, 3DEXPERIENCE, serveur de licences). Alternative : Pas de flux RSS publié (page HTML uniquement, vérifié le 31/10/2026). Les CVE Dassault Systèmes remontent par le NVD, le catalogue CISA KEV et les avis CERT-FR, collectés automatiquement ; consultation manuelle mensuelle de la page.
Debian — Security Advisories (DSA)	Éditeur / fournisseur / Élevée	12 h	Fonctionnelle	33	Bulletins de sécurité officiels de Debian.
Feedly — Flux personnels (API officielle)	Communauté / fondation / agrégateur / Moyenne	6 h	Désactivée	0	Source complémentaire facultative : agrège les flux suivis dans le compte Feedly de l'utilisateur. La fiabilité dépend des flux d'origine (indiqués pour chaque article). Alternative : Nécessite un jeton d'accès API officiel (variable FEEDLY_ACCESS_TOKEN), disponible selon l'offre Feedly. Sans jeton : exporter ses abonnements en OPML depuis Feedly et les importer dans le catalogue (page Sources) ; l'application les collecte alors directement en RSS. Voir docs/FEEDLY.md.
Fortinet — PSIRT Advisories	Éditeur / fournisseur / Élevée	12 h	Fonctionnelle	13	Avis officiels Fortinet ; équipements fréquemment ciblés en périmètre réseau.
Krebs on Security	Presse spécialisée / Moyenne	24 h	Fonctionnelle	7	Enquêtes sur la cybercriminalité et les incidents majeurs.
Microsoft Security Blog	Éditeur / fournisseur / Moyenne	24 h	Fonctionnelle	12	Renseignement sur la menace (Microsoft Threat Intelligence) et nouveautés sécurité.
Microsoft — Security Update Guide	Éditeur / fournisseur / Élevée	12 h	Fonctionnelle	153	Source primaire des vulnérabilités et correctifs Microsoft (flux volumineux, limité aux 150 entrées les plus récentes).
NCSC (Royaume-Uni) — Publications	Source officielle / Élevée	24 h	Fonctionnelle	9	Agence nationale homologue de l'ANSSI ; guides et recommandations de sécurité.
Palo Alto Networks — Unit 42	Recherche / laboratoire / Moyenne	12 h	Fonctionnelle	15	Analyses de campagnes et de modes opératoires ; source éditeur.
SANS Internet Storm Center — Diaries	Recherche / laboratoire / Élevée	6 h	Fonctionnelle	3	Analyses techniques quotidiennes par des incident handlers (observations terrain, détection).
Securelist (Kaspersky GReAT)	Recherche / laboratoire / Moyenne	12 h	Fonctionnelle	10	Analyses APT et logiciels malveillants ; à recouper (contexte géopolitique de l'éditeur).
SecurityWeek	Presse spécialisée / Moyenne	6 h	Fonctionnelle	16	Actualité vulnérabilités, ICS et réglementation.
The DFIR Report	Recherche / laboratoire / Moyenne	24 h	Fonctionnelle	0	Retours d'expérience détaillés d'intrusions réelles (chaînes d'attaque, détections).
The Hacker News	Presse spécialisée / Moyenne	3 h	Fonctionnelle	54	Couverture large des menaces et vulnérabilités ; contenu parfois sponsorisé, à recouper.
Ubuntu — Security Notices	Éditeur / fournisseur / Élevée	12 h	Fonctionnelle	11	Bulletins de sécurité officiels de la distribution Ubuntu.

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
WeLiveSecurity (ESET) — FR	Recherche / laboratoire / Moyenne	12 h	Fonctionnelle	7	Recherches sur les logiciels malveillants en français ; source éditeur (biais commercial possible).
ZATAZ	Presse spécialisée / Moyenne	6 h	Fonctionnelle	7	Actualité francophone sur les fuites de données et la cybercriminalité ; à recouper.
nginx — Actualités (correctifs de sécurité)	Éditeur / fournisseur / Élevée	24 h	Fonctionnelle	1	Annonces officielles de versions correctives de nginx (serveur de l'intranet).

Veille réglementaire

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
Autorité bancaire européenne (EBA) — Actualités (filtrées)	Source officielle / Élevée	24 h	Désactivée	1	Normes techniques et orientations liées à DORA pour le secteur financier. Alternative : Désactivée pour le profil AéroStar : DORA ne concerne que le secteur financier (applicabilité peu probable). À réactiver si l'organisation travaille pour des entités financières.
CNIL — Actualités	Source officielle / Élevée	12 h	Fonctionnelle	10	Autorité française de protection des données ; recommandations, sanctions, référentiels RGPD.
Commission européenne — AI Act Service Desk	Source officielle / Élevée	24 h	Fonctionnelle	0	Point d'information officiel de la Commission sur la mise en œuvre du règlement IA.
Commission européenne — Stratégie numérique (filtrée)	Source officielle / Élevée	24 h	Fonctionnelle	2	Annonces officielles (actes d'exécution, consultations, lignes directrices) sur NIS2, AI Act, CRA, eIDAS.
EASA — Actualités (filtrées cybersécurité)	Source officielle / Élevée	24 h	Fonctionnelle	0	Autorité européenne de l'aviation : publications relatives au règlement Part-IS (sécurité de l'information), susceptibles d'être répercutées par les clients de rang 1 sur leurs sous-traitants.
EDPB — Actualités	Source officielle / Élevée	24 h	Fonctionnelle	9	Lignes directrices et décisions contraignantes interprétant le RGPD au niveau européen.
EUR-Lex — Actes du Journal officiel série L (filtrés)	Source officielle / Élevée	24 h	Fonctionnelle	1	Actes publiés au JOUE, notamment les règlements d'exécution et délégués précisant NIS2, DORA, AI Act, CRA.
EUR-Lex — Législation du Parlement et du Conseil (filtrée)	Source officielle / Élevée	24 h	Fonctionnelle	1	Source officielle des textes législatifs de l'UE (identifiant CELEX, date de publication). Flux généraliste : un filtre par mots-clés ne conserve que les textes liés au numérique et à la sécurité.
EUR-Lex — Propositions de la Commission (filtrées)	Source officielle / Élevée	24 h	Fonctionnelle	3	Propositions législatives (statut « projet ») permettant d'anticiper les évolutions réglementaires.
Légifrance — Journal officiel (JORF)	Source officielle / Élevée	168 h	Bloquée / non collectable	0	Source officielle des textes législatifs et réglementaires français (transposition NIS2, lois, décrets). Alternative : Les flux RSS publics de Légifrance renvoient une page de vérification anti-robot (HTTP 403, Cloudflare) : aucune collecte automatique n'est tentée. Alternatives : (1) API Légifrance officielle via le portail PISTE (compte et identifiants OAuth requis, piste.gouv.fr) ; (2) consultation manuelle hebdomadaire et saisie dans l'outil ; (3) suivi des textes européens via EUR-Lex.
Sénat — Derniers rapports (filtrés)	Source officielle / Élevée	24 h	Fonctionnelle	0	Rapports de commission (dont ceux sur le projet de loi de transposition NIS 2) éclairant le contenu et le calendrier des obligations.

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
Sénat — Derniers textes (filtrés)	Source officielle / Élevée	24 h	Fonctionnelle	0	Textes déposés et adoptés au Sénat : permet de suivre l'avancement du projet de loi de transposition de NIS 2 (en discussion au Parlement en octobre 2026), Légifrance n'étant pas collectable automatiquement.
artificialintelligenceact.eu (non officiel)	Communauté / fondation / agrégateur / Moyenne	24 h	Fonctionnelle	6	Site d'analyse NON officiel du règlement IA, utile pour suivre les débats ; toute information doit être confirmée sur EUR-Lex.

Veille normative

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
ANSSI — Guides et publications (cyber.gouv.fr)	Source officielle / Élevée	168 h	Bloquée / non collectable	0	Guides d'hygiène, recommandations de configuration, référentiels (SecNumCloud, PASSI, etc.). Alternative : Le site cyber.gouv.fr est protégé par un dispositif anti-robot (Incapsula) et ne fournit pas de flux RSS exploitable : aucune collecte automatique n'est tentée. Alternatives : les flux CERT-FR (même organisme) sont collectés automatiquement ; consultation manuelle mensuelle de la page des publications et saisie des nouveautés dans l'outil.
BoostAeroSpace — Actualités (AirCyber)	Source officielle / Élevée	168 h	Fonctionnelle	0	Opérateur du référentiel de maturité AirCyber exigé par les clients (Bronze fin 2027). Flux valide mais sans publication au 31/10/2026 ; surveillé pour détecter toute évolution du programme.
ISO Open Data — Métadonnées des normes surveillées	Source officielle / Élevée	168 h	Fonctionnelle	0	Jeu de données ouvert publié par l'ISO (métadonnées : référence, titre, édition, stade, date de publication, remplacements). Permet de détecter une nouvelle édition, un amendement ou une révision sans accéder au texte des normes, qui reste payant et n'est jamais reproduit.
NIST — Actualités (filtrées sécurité)	Source officielle / Élevée	24 h	Fonctionnelle	2	Actualités officielles du NIST, filtrées sur la sécurité (normes FIPS, SP 800, PQC, IA).
NIST — Cybersecurity Insights (blog)	Source officielle / Élevée	24 h	Fonctionnelle	4	Annonces du NIST sur le Cybersecurity Framework, les SP 800, la cryptographie post-quantique et la sécurité de l'IA.
OpenSSF — Blog	Communauté / fondation / agrégateur / Moyenne	24 h	Fonctionnelle	10	Référentiels de bonnes pratiques pour la sécurité de la chaîne d'approvisionnement logicielle (SLSA, SBOM).

Veille technologique

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
AWS Security Blog	Éditeur / fournisseur / Moyenne	24 h	Désactivée	19	Nouveautés et bonnes pratiques de sécurité AWS (IAM, détection, chiffrement). Alternative : Désactivée pour le profil AéroStar : pas d'usage d'AWS déclaré (le cloud se limite à Microsoft 365 et à l'ERP en SaaS). À réactiver si besoin.
CNCF — Blog	Communauté / fondation / agrégateur / Moyenne	24 h	Désactivée	7	Tendances cloud natif (sécurité des conteneurs, identité des charges de travail, IA). Alternative : Désactivée pour le profil AéroStar : pas d'environnement cloud natif. À réactiver si besoin.
Cloudflare Blog	Éditeur / fournisseur / Moyenne	24 h	Fonctionnelle	22	Retours techniques sur le déploiement post-quantique, le Zero Trust et les attaques DDoS.

Source	Nature / confiance	Fréquence	État	Éléments retenus	Justification
CrowdStrike Blog	Éditeur / fournisseur / Moyenne	24 h	Fonctionnelle	14	Tendances EDR/XDR et sécurité de l'IA ; source éditeur (biais commercial).
Elastic Security Labs	Recherche / laboratoire / Moyenne	24 h	Fonctionnelle	8	Recherches sur l'ingénierie de détection et les nouvelles techniques d'attaque.
GitHub Blog — Security	Éditeur / fournisseur / Moyenne	24 h	Fonctionnelle	5	DevSecOps, sécurité des dépendances, analyse de code, gestion des secrets.
Google Online Security Blog	Éditeur / fournisseur / Moyenne	24 h	Fonctionnelle	0	Innovations (post-quantique, sécurité de l'IA, mémoire sûre) publiées par les équipes sécurité de Google.
Kubernetes Blog (filtré sécurité)	Communauté / fondation / agrégateur / Élevée	24 h	Désactivée	3	Annonces officielles du projet Kubernetes (fonctionnalités de sécurité, dépréciations). Alternative : Désactivée pour le profil AéroStar : pas de conteneurs dans le SI. À réactiver si un projet d'orchestration de conteneurs est lancé.
Schneier on Security	Recherche / laboratoire / Moyenne	24 h	Fonctionnelle	12	Analyses d'expert reconnu en cryptographie et en politique de sécurité.

6. Résultats de la veille technique et cybersécurité

Catégorie	Éléments
Vulnérabilité ou correctif	470
Menace ou campagne d'attaque	111
Incident ou retour d'expérience	54
Bonne pratique ou recommandation	33

[Analyse] Technologies du parc les plus citées : Microsoft 365 (Exchange Online, Teams, SharePoint) (4), Pare-feu et VPN SSL (géré par l'infogérant) (3), Intranet (nginx) (3), Active Directory (corp.aerostar.lan) (1), Serveur de fichiers du BE (partages SMB, ~8 To) (1).

Bonnes pratiques et recommandations publiées

Kicking off Cybersecurity Career Week with NIST!

https://www.nist.gov/blogs/cybersecurity-insights/kicking-cybersecurity-career-week-nist

Source : NIST — Cybersecurity Insights (blog) — publié le 2026-10-14, consulté le 2026-10-29

Catégorie : Bonne pratique ou recommandation, Évolution normative — mots-clés : awareness, how to, NIST Cybersecurity Framework 2.0

[Analyse] Résumé : Bonne pratique ou recommandation — publication de NIST — Cybersecurity Insights (blog) du 2026-10-14. Extrait original (en) : « Considering a career in cybersecurity? Cybersecurity Career Week (CCW), a campaign led by the NICE Program at NIST from October 19-24, 2026, aims to raise public awareness and help people find their path to #ChooseCyber. During this week, academia, industry, non-profit organizations, and government agencies host events, share resources, provide […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : a_qualifier — Applicabilité du texte à qualifier.

[Analyse] Priorité : À qualifier — Score 8 = 8 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : a_qualifier.

[Recommandation] : (1) Évaluer l'impact de l'évolution de « NIST Cybersecurity Framework 2.0 » (référentiel de bonnes pratiques) sur les pratiques de sécurité, les engagements contractuels et, le cas échéant, le SMSI. (2) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégrer les mesures pertinentes au plan d'amélioration. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Qualification requise (sous 7 jours)

Confiance de l'analyse : moyenne

Siemens Software Center

https://www.cisa.gov/news-events/ics-advisories/icsa-26-295-03

Source : CISA — Cybersecurity Advisories — publié le 2026-10-22, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif, Bonne pratique ou recommandation — mots-clés : vulnerabilit, CVE, code execution, exploitation, recommend, guide, how to

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Cybersecurity Advisories du 2026-10-22. CVE citées : CVE-2026-110936. Produits cités : Siemens, Software Center. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « View CSAF Summary The affected application loads dynamic-link libraries (DLLs) from an uncontrolled search path. This could allow an authenticated local attacker to place a specially crafted DLL in a directory that the application searches, leading to arbitrary code execution with the privileges of the affected application. Siemens has released a […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Siemens, Software Center

[Donnée vérifiée] CVE : CVE-2026-110936 — CVSS non disponible, EPSS 0.01, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Siemens, Software Center.

[Analyse] Priorité : Modérée — Score 42 = 12 (Gravité technique) + 30 (Exploitation active) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible.

[Recommandation] : (1) Vérifier si Siemens, Software Center est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégrer les mesures pertinentes au plan d'amélioration. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Score CVSS de CVE-2026-110936 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Présence éventuelle dans le parc à confirmer : Siemens, Software Center.

Critical security issue affecting PHP

https://www.ncsc.gov.uk/news/critical-security-issue-affecting-php

Source : NCSC (Royaume-Uni) — Publications — publié le 2026-10-21, consulté le 2026-10-29

Catégorie : Bonne pratique ou recommandation

[Analyse] Résumé : Bonne pratique ou recommandation — publication de NCSC (Royaume-Uni) — Publications du 2026-10-21. CVE citées : CVE-2026-109618, CVE-2026-109619. Produits cités : PHP. Exploitation active confirmée (catalogue CISA KEV). Extrait original (en) : « Updated: The NCSC is encouraging UK organisations to take immediate action to mitigate a security issue affecting PHP (CVE-2026-109618 and CVE-2026-109619). » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : PHP

[Donnée vérifiée] CVE : CVE-2026-109618 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée; CVE-2026-109619 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : PHP.

[Analyse] Priorité : Modérée — Score 40 = 30 (Exploitation active) + 10 (Probabilité d'exploitation) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible.

[Recommandation] : (1) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégrer les mesures pertinentes au plan d'amélioration. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Score CVSS de CVE-2026-109618 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Score CVSS de CVE-2026-109619 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur.

Using AWS WAF to apply mitigations for PHP2Shell RCE vulnerabilities (CVE-2026-109618 and CVE-2026-109619)

https://aws.amazon.com/blogs/security/using-aws-waf-to-apply-mitigations-for-php2shell-rce-vulnerabilities-cve-2026-109618-and-cve-2026-109619/

Source : AWS Security Blog — publié le 2026-10-22, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif, Bonne pratique ou recommandation — mots-clés : vulnerabilit, CVE, RCE, code execution, guidance, mitigation

[Analyse] Résumé : Vulnérabilité ou correctif — publication de AWS Security Blog du 2026-10-22. CVE citées : CVE-2026-109618, CVE-2026-109619, CVE-2026-115560. Produits cités : PHP. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « October 29, 2026: We added guidance for end-of-life PHP versions (8.1 and earlier), including the source backports that the PHP security team published for PHP 7.4, 8.0, and 8.1. October 23, 2026 (update 2): The PHP project disclosed CVE-2026-115560, a separate remote code execution issue that the October 21 releases don’t fix. It affects only […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : PHP

[Donnée vérifiée] CVE : CVE-2026-109618 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée; CVE-2026-109619 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée; CVE-2026-115560 — CVSS non disponible

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : PHP.

[Analyse] Priorité : Modérée — Score 40 = 30 (Exploitation active) + 10 (Probabilité d'exploitation) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible.

[Recommandation] : (1) Vérifier si PHP est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégrer les mesures pertinentes au plan d'amélioration. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Score CVSS de CVE-2026-109618 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Score CVSS de CVE-2026-109619 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Score CVSS de CVE-2026-115560 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Présence éventuelle dans le parc à confirmer : PHP. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

De la protection des données à la création de valeur en finance : des autorités européennes publient une étude et des bonnes pratiques

https://www.cnil.fr/fr/protection-donnees-valeur-finance-etude-autorites-europeennes

Source : CNIL — Actualités — publié le 2026-10-16, consulté le 2026-10-29

Catégorie : Évolution réglementaire, Bonne pratique ou recommandation — mots-clés : CNIL, protection des données, bonnes pratiques, RGPD

[Fait] Résumé : La CNIL, l'ICO et la CNPD publient leur étude conjointe « De la protection des données à la création de valeur en finance : évaluation des données, comptabilité, fusions-acquisitions et gouvernance », rassemblant analyses et bonnes pratiques à destination des entreprises et des acteurs financiers.

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégrer les mesures pertinentes au plan d'amélioration. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

7. Menaces et vulnérabilités identifiées

Vulnérabilités

[Élevée] Cisco Secure Firewall Adaptive Security Appliance and Secure Firewall Threat Defense Software Remote Access SSL VPN Tunnel Denial of Service Vulnerability

https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-tunnel-dos-s6mgkb75?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Secure%20Firewall%20Adaptive%20Security%20Appliance%20and%20Secure%20Firewall%20Threat%20Defense%20Software%20Remote%20Access%20SSL%20VPN%20Tunnel%20Denial%20of%20Service%20Vulnerability%26vs_k=1

Source : Cisco — Security Advisories — publié le 2026-10-28, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, advisory, denial of service

[Analyse] Résumé : Vulnérabilité ou correctif — publication de Cisco — Security Advisories du 2026-10-28. CVE citées : CVE-2026-76418. Produits cités : Secure Firewall ASA Software and Cisco Secure FTD Software. Technologies du parc concernées : Pare-feu et VPN SSL (géré par l'infogérant). Exploitation active confirmée (catalogue CISA KEV). Thèmes : Zero Trust, IAM, MFA et gestion des identités, Sécurité du cloud, des conteneurs et de la chaîne logicielle. Extrait original (en) : « A vulnerability in the Remote Access SSL VPN service of Cisco Secure Firewall Adaptive Security Appliance (ASA) Software and Cisco Secure Firewall Threat Defense (FTD) Software could allow an unauthenticated, remote attacker to cause the device to reload unexpectedly, resulting in a denial of service (DoS) condition. This vulnerability is due to […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Pare-feu et VPN SSL (géré par l'infogérant) (exposition : internet, criticité : critique, versions du parc : n.c.)

[Donnée vérifiée] CVE : CVE-2026-76418 — CVSS non disponible, EPSS 0.01, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Disponibilité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Pare-feu et VPN SSL (géré par l'infogérant).

[Analyse] Priorité : Élevée — Score 75 = 30 (Exploitation active) + 10 (Présence dans le parc) + 15 (Exposition) + 10 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte. Plafonné à « Élevée » : le niveau « Critique » exige une technologie du parc identifiée (marque connue) ET une gravité ou une exploitation vérifiée (KEV, CVSS ≥ 9, alerte CERT-FR).

[Recommandation] : (1) Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire. (2) Vérifier la présence et les versions de Pare-feu et VPN SSL (géré par l'infogérant) concernées par l'avis (inventaire, outil de gestion de parc). (3) Demander à l'infogérant l'application du correctif sur Pare-feu et VPN SSL (géré par l'infogérant) et une confirmation écrite (modèle, version, date), à conserver comme preuve. (4) En attendant le correctif, réduire l'exposition (filtrage des accès, désactivation de la fonctionnalité vulnérable) selon les recommandations de l'éditeur. (5) Rechercher des traces d'exploitation dans les journaux disponibles (serveurs concernés, contrôleurs de domaine, pare-feu, SIEM/EDR s'il existe) depuis la date de divulgation, à l'aide des indicateurs publiés. (6) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (7) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : elevee

[À vérifier] : Score CVSS de CVE-2026-76418 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Marque et modèle de « Pare-feu et VPN SSL (géré par l'infogérant) » non documentés : confirmer auprès du gestionnaire si l'avis s'applique.

[Élevée] CVE-2026-70125 Microsoft Office Outlook Remote Code Execution Vulnerability

https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70125

Source : Microsoft — Security Update Guide — publié le 2026-10-30, consulté le 2026-10-31

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, code execution

[Analyse] Résumé : Vulnérabilité ou correctif — publication de Microsoft — Security Update Guide du 2026-10-30. CVE citées : CVE-2026-70125. Score CVSS le plus élevé (NVD) : 7.8 (CVE-2026-70125). Produits cités : Microsoft, Office, Outlook. Technologies du parc concernées : Microsoft 365 (Exchange Online, Teams, SharePoint). Extrait original (en) : « Updated one or more CVSS scores for the affected products. This is an informational change only. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Microsoft 365 (Exchange Online, Teams, SharePoint) (exposition : internet, criticité : elevee, versions du parc : n.c.)

[Donnée vérifiée] CVE : CVE-2026-70125 — CVSS 7.8 (HIGH, NVD (secure@microsoft.com, Primary)), EPSS 0.00

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Intégrité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Microsoft 365 (Exchange Online, Teams, SharePoint).

[Analyse] Priorité : Élevée — Score 66 = 20 (Gravité technique) + 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Vérifier la présence et les versions de Microsoft 365 (Exchange Online, Teams, SharePoint) concernées par l'avis (inventaire, outil de gestion de parc). (2) Service géré par le fournisseur (Microsoft 365 (Exchange Online, Teams, SharePoint)) : vérifier l'avis du fournisseur et les actions éventuellement requises côté client (configuration, MFA, journaux) — responsabilité partagée. (3) En attendant le correctif, réduire l'exposition (filtrage des accès, désactivation de la fonctionnalité vulnérable) selon les recommandations de l'éditeur. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : elevee

[À vérifier] : Versions affectées de Microsoft 365 (Exchange Online, Teams, SharePoint) à comparer avec les versions du parc (non renseignées).

[Élevée] New Cisco firewall zero-day exploited to crash SSL VPN devices

https://www.bleepingcomputer.com/news/security/cisco-warns-of-firewall-zero-day-exploited-to-crash-ssl-vpn-devices/

Source : BleepingComputer — publié le 2026-10-29, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : patch, security update, zero-day, exploited

[Analyse] Résumé : Vulnérabilité ou correctif — publication de BleepingComputer du 2026-10-29. Produits cités : Cisco. Technologies du parc concernées : Pare-feu et VPN SSL (géré par l'infogérant). Exploitation active signalée par la source — non confirmée par le KEV. Extrait original (en) : « Cisco released security updates to patch a denial-of-service zero-day in Adaptive Security Appliance (ASA) and Threat Defense (FTD) software that attackers are exploiting to remotely crash vulnerable firewall devices. […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Pare-feu et VPN SSL (géré par l'infogérant) (exposition : internet, criticité : critique, versions du parc : n.c.)

Exploitation : Exploitation active signalée par la source — non confirmée par le KEV

[Analyse] Impact potentiel : Disponibilité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Pare-feu et VPN SSL (géré par l'infogérant).

[Analyse] Priorité : Élevée — Score 63 = 18 (Exploitation active) + 10 (Présence dans le parc) + 15 (Exposition) + 10 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire. (2) Vérifier la présence et les versions de Pare-feu et VPN SSL (géré par l'infogérant) concernées par l'avis (inventaire, outil de gestion de parc). (3) Demander à l'infogérant l'application du correctif sur Pare-feu et VPN SSL (géré par l'infogérant) et une confirmation écrite (modèle, version, date), à conserver comme preuve. (4) En attendant le correctif, réduire l'exposition (filtrage des accès, désactivation de la fonctionnalité vulnérable) selon les recommandations de l'éditeur. (5) Rechercher des traces d'exploitation dans les journaux disponibles (serveurs concernés, contrôleurs de domaine, pare-feu, SIEM/EDR s'il existe) depuis la date de divulgation, à l'aide des indicateurs publiés. (6) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (7) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : faible

[À vérifier] : Exploitation active signalée par la source mais non confirmée par le catalogue CISA KEV. Marque et modèle de « Pare-feu et VPN SSL (géré par l'infogérant) » non documentés : confirmer auprès du gestionnaire si l'avis s'applique. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Élevée] nginx-1.30.6 stable and nginx-1.31.7 mainline versions have been released, with fixes for buffer overflow vulnerability when using alias with rewrite (CVE-2026-15176), buffer overflow vulnerability when evaluating string expressions with variables (CVE-2026-93479), request body injection vulnerability in HTTP/3 (CVE-2026-95101), session forgery vulnerability when using TLS session ticket key [...]

http://nginx.org/#2026-10-14

Source : nginx — Actualités (correctifs de sécurité) — publié le 2026-10-13, consulté le 2026-10-31

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, injection, buffer overflow

[Analyse] Résumé : Vulnérabilité ou correctif — publication de nginx — Actualités (correctifs de sécurité) du 2026-10-13. CVE citées : CVE-2026-15176, CVE-2026-93479, CVE-2026-95101, CVE-2026-97629, CVE-2026-97205. Score CVSS le plus élevé (NVD) : 9.2 (CVE-2026-15176). Produits cités : Nginx. Technologies du parc concernées : Intranet (nginx). Thèmes : Cryptographie, post-quantique et gestion des secrets. Extrait original (en) : « 2026-10-14 nginx-1.30.6 stable and nginx-1.31.7 mainline versions have been released, with fixes for buffer overflow vulnerability when using alias with rewrite (CVE-2026-15176), buffer overflow vulnerability when evaluating string expressions with variables (CVE-2026-93479), request body injection vulnerability in HTTP/3 (CVE-2026-95101), session [...] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Intranet (nginx) (exposition : interne, criticité : faible, versions du parc : n.c.)

[Donnée vérifiée] CVE : CVE-2026-15176 — CVSS 9.2 (CRITICAL, NVD (f5sirt@f5.com, Secondary)), EPSS 0.01; CVE-2026-93479 — CVSS 9.2 (CRITICAL, NVD (f5sirt@f5.com, Secondary)), EPSS 0.01; CVE-2026-95101 — CVSS 6.9 (MEDIUM, NVD (f5sirt@f5.com, Secondary)), EPSS 0.00; CVE-2026-97629 — CVSS 8.3 (HIGH, NVD (f5sirt@f5.com, Secondary)), EPSS 0.00; CVE-2026-97205 — CVSS 9.2 (CRITICAL, NVD (f5sirt@f5.com, Secondary)), EPSS 0.01

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Intégrité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Intranet (nginx).

[Analyse] Priorité : Élevée — Score 55 = 30 (Gravité technique) + 25 (Présence dans le parc) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Vérifier la présence et les versions de Intranet (nginx) concernées par l'avis (inventaire, outil de gestion de parc). (2) Appliquer le correctif de l'éditeur selon la procédure de gestion des correctifs (test, puis déploiement prioritaire). (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : elevee

[À vérifier] : Versions affectées de Intranet (nginx) à comparer avec les versions du parc (non renseignées).

[Élevée] USN-8955-1: nginx vulnerabilities

https://ubuntu.com/security/notices/USN-8955-1

Source : Ubuntu — Security Notices — publié le 2026-10-26, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, bypass, USN, denial of service

[Analyse] Résumé : Vulnérabilité ou correctif — publication de Ubuntu — Security Notices du 2026-10-26. CVE citées : CVE-2026-15176, CVE-2026-93479, CVE-2026-95101, CVE-2026-97205, CVE-2026-97629. Score CVSS le plus élevé (NVD) : 9.2 (CVE-2026-15176). Produits cités : Ubuntu, Nginx. Technologies du parc concernées : Intranet (nginx). Thèmes : Cryptographie, post-quantique et gestion des secrets. Extrait original (en) : « It was discovered that nginx incorrectly handled certain configurations using the alias directive together with rewrite rules. A remote attacker could possibly use this issue to cause nginx to crash, resulting in a denial of service, or execute arbitrary code. (CVE-2026-15176) It was discovered that nginx incorrectly handled map directives using [...] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Intranet (nginx) (exposition : interne, criticité : faible, versions du parc : n.c.)

[Donnée vérifiée] CVE : CVE-2026-15176 — CVSS 9.2 (CRITICAL, NVD (f5sirt@f5.com, Secondary)), EPSS 0.01; CVE-2026-93479 — CVSS 9.2 (CRITICAL, NVD (f5sirt@f5.com, Secondary)), EPSS 0.01; CVE-2026-95101 — CVSS 6.9 (MEDIUM, NVD (f5sirt@f5.com, Secondary)), EPSS 0.00; CVE-2026-97205 — CVSS 9.2 (CRITICAL, NVD (f5sirt@f5.com, Secondary)), EPSS 0.01; CVE-2026-97629 — CVSS 8.3 (HIGH, NVD (f5sirt@f5.com, Secondary)), EPSS 0.00

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Intranet (nginx).

[Analyse] Priorité : Élevée — Score 55 = 30 (Gravité technique) + 25 (Présence dans le parc) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Vérifier la présence et les versions de Intranet (nginx) concernées par l'avis (inventaire, outil de gestion de parc). (2) Appliquer le correctif de l'éditeur selon la procédure de gestion des correctifs (test, puis déploiement prioritaire). (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : elevee

[À vérifier] : Versions affectées de Intranet (nginx) à comparer avec les versions du parc (non renseignées).

[Modérée] [KEV] CVE-2015-3306 — ProFTPD ProFTPD : ProFTPD Improper Access Control Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2015-3306

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, KEV, exploitation, catalogue KEV

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-08. CVE citées : CVE-2015-3306. Score CVSS le plus élevé (NVD) : 10.0 (CVE-2015-3306). Produits cités : ProFTPD. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « ProFTPD contains an improper access control vulnerability that could allow remote attackers to read and write to arbitrary files via the site cpfr and site cpto commands. Ajoutée au catalogue KEV le 2026-10-08 (exploitation active confirmée par la CISA). Action requise (CISA) : Apply mitigations in accordance with vendor instructions, ensuring […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : ProFTPD

[Donnée vérifiée] CVE : CVE-2015-3306 — CVSS 10.0 (CRITICAL, NVD (134c704f-9b21-4f2e-91b3-4a467353bcc0, Secondary)), EPSS 0.99, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : ProFTPD.

[Analyse] Priorité : Modérée — Score 80 = 30 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Plafonné à « Élevée » : le niveau « Critique » exige une technologie du parc identifiée (marque connue) ET une gravité ou une exploitation vérifiée (KEV, CVSS ≥ 9, alerte CERT-FR). Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si ProFTPD est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : ProFTPD.

[Modérée] [KEV] CVE-2026-111497 — Google Brotli : Google Brotli Unchecked Return Value Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-111497

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-27, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, KEV, exploitation, denial of service, catalogue KEV

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-27. CVE citées : CVE-2026-111497. Score CVSS le plus élevé (NVD) : 9.2 (CVE-2026-111497). Produits cités : Brotli. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « Google Brotli contains an unchecked return value vulnerability that allows a remote unauthenticated attacker to corrupt adjacent decoder state memory, disclose sensitive memory contents, cause a denial of service, or potentially execute arbitrary code using a crafted Brotli-compressed stream. Ajoutée au catalogue KEV le 2026-10-27 (exploitation […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Brotli

[Donnée vérifiée] CVE : CVE-2026-111497 — CVSS 9.2 (CRITICAL, NVD (cve-coordination@google.com, Secondary)), EPSS 0.83, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Brotli.

[Analyse] Priorité : Modérée — Score 80 = 30 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Plafonné à « Élevée » : le niveau « Critique » exige une technologie du parc identifiée (marque connue) ET une gravité ou une exploitation vérifiée (KEV, CVSS ≥ 9, alerte CERT-FR). Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si Brotli est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : Brotli.

[Modérée] [KEV] CVE-2021-3199 — ONLYOFFICE Docs : ONLYOFFICE Docs Server Path Traversal Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2021-3199

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, code execution, KEV, exploitation, catalogue KEV

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-08. CVE citées : CVE-2021-3199. Score CVSS le plus élevé (NVD) : 9.8 (CVE-2021-3199). Produits cités : Docs. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « ONLYOFFICE Docs contains a path traversal vulnerability that can occur when JWT is used, via a /.. sequence in an image upload parameter and could allow for remote code execution. Ajoutée au catalogue KEV le 2026-10-08 (exploitation active confirmée par la CISA). Action requise (CISA) : Apply mitigations in accordance with vendor instructions, […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Docs

[Donnée vérifiée] CVE : CVE-2021-3199 — CVSS 9.8 (CRITICAL, NVD (nvd@nist.gov, Primary)), EPSS 0.30, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Docs.

[Analyse] Priorité : Modérée — Score 75 = 30 (Gravité technique) + 30 (Exploitation active) + 5 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Plafonné à « Élevée » : le niveau « Critique » exige une technologie du parc identifiée (marque connue) ET une gravité ou une exploitation vérifiée (KEV, CVSS ≥ 9, alerte CERT-FR). Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si Docs est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : Docs.

[Modérée] [KEV] CVE-2026-97229 — GitLab Community Edition and Enterprise Edition : GitLab Community Edition and Enterprise Edition Integer Overflow or Wraparound Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-97229

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-29, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, KEV, exploitation, catalogue KEV

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-29. CVE citées : CVE-2026-97229. Score CVSS le plus élevé (NVD) : 10.0 (CVE-2026-97229). Produits cités : GitLab, Community Edition and Enterprise Edition. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, DevSecOps, SBOM et sécurité des dépendances, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « GitLab Community Edition and Enterprise Edition contain a integer overflow or wraparound vulnerability that could allow an unauthenticated user to execute arbitrary code on the GitLab server via a specially crafted regular expression in a CI/CD configuration, due to insufficient regular expression validation. Ajoutée au catalogue KEV le 2026-10-29 […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : GitLab, Community Edition and Enterprise Edition

[Donnée vérifiée] CVE : CVE-2026-97229 — CVSS 10.0 (CRITICAL, NVD (cve@gitlab.com, Secondary)), EPSS 0.27, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : GitLab, Community Edition and Enterprise Edition.

[Analyse] Priorité : Modérée — Score 75 = 30 (Gravité technique) + 30 (Exploitation active) + 5 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Plafonné à « Élevée » : le niveau « Critique » exige une technologie du parc identifiée (marque connue) ET une gravité ou une exploitation vérifiée (KEV, CVSS ≥ 9, alerte CERT-FR). Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si GitLab, Community Edition and Enterprise Edition est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : GitLab, Community Edition and Enterprise Edition.

[Modérée] [KEV] CVE-2023-22894 — Strapi Strapi : Strapi Cleartext Storage of Sensitive Information Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2023-22894

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, code execution, KEV, exploitation, catalogue KEV

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-08. CVE citées : CVE-2023-22894, CVE-2023-22621. Score CVSS le plus élevé (NVD) : 7.2 (CVE-2023-22621). Produits cités : Strapi. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « Strapi contains a cleartext storage of sensitive information vulnerability that could allow attackers with access to the admin panel to discover sensitive user details via the query filter. The impacted product(s) could be end-of-life (EoL) and/or end-of-service (EoS). Users are advised to discontinue use and/or transition to a supported version. […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Strapi

[Donnée vérifiée] CVE : CVE-2023-22894 — CVSS 4.9 (MEDIUM, NVD (nvd@nist.gov, Primary)), EPSS 0.04, KEV : exploitation active confirmée; CVE-2023-22621 — CVSS 7.2 (HIGH, NVD (nvd@nist.gov, Primary)), EPSS 0.71

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Strapi.

[Analyse] Priorité : Modérée — Score 70 = 20 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si Strapi est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : Strapi.

[Modérée] [KEV] CVE-2016-3081 — Apache Struts : Apache Struts Command Injection Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2016-3081

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, injection, KEV, exploitation, catalogue KEV

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-08. CVE citées : CVE-2016-3081. Score CVSS le plus élevé (NVD) : 8.1 (CVE-2016-3081). Produits cités : Apache, Struts. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « Apache Struts contains a command injection vulnerability that could allow remote attackers to execute arbitrary code via method:prefix when Dynamic Method Invocation is enabled. Ajoutée au catalogue KEV le 2026-10-08 (exploitation active confirmée par la CISA). Action requise (CISA) : Apply mitigations in accordance with vendor instructions, […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Apache, Struts

[Donnée vérifiée] CVE : CVE-2016-3081 — CVSS 8.1 (HIGH, NVD (nvd@nist.gov, Primary)), EPSS 0.97, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Apache, Struts.

[Analyse] Priorité : Modérée — Score 70 = 20 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si Apache, Struts est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : Apache, Struts.

[Modérée] [KEV] CVE-2015-5477 — ISC BIND : ISC BIND Data Processing Errors Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2015-5477

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, KEV, exploitation, denial of service, catalogue KEV

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-08. CVE citées : CVE-2015-5477. Score CVSS le plus élevé (NVD) : 7.5 (CVE-2015-5477). Produits cités : BIND. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « ISC BIND contains a data processing errors vulnerability that could allow remote attackers to cause a denial of service via TKEY queries. Ajoutée au catalogue KEV le 2026-10-08 (exploitation active confirmée par la CISA). Action requise (CISA) : Apply mitigations in accordance with vendor instructions, ensuring compliance with CISA’s BOD 26-04 […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : BIND

[Donnée vérifiée] CVE : CVE-2015-5477 — CVSS 7.5 (HIGH, NVD (134c704f-9b21-4f2e-91b3-4a467353bcc0, Secondary)), EPSS 1.00, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : BIND.

[Analyse] Priorité : Modérée — Score 70 = 20 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si BIND est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : BIND.

[Modérée] [KEV] CVE-2026-104935 — Ivanti Connect Secure : Ivanti Connect Secure Authentication Bypass by Spoofing Vulnerability

https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-104935

Source : CISA — Known Exploited Vulnerabilities (KEV) — publié le 2026-10-13, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnerabilit, CVE, patch, security update, bypass, KEV, exploitation, spoofing

[Analyse] Résumé : Vulnérabilité ou correctif — publication de CISA — Known Exploited Vulnerabilities (KEV) du 2026-10-13. CVE citées : CVE-2026-104935. Score CVSS le plus élevé (NVD) : 8.6 (CVE-2026-104935). Produits cités : Ivanti, Connect Secure. Exploitation active confirmée (catalogue CISA KEV). Thèmes : Zero Trust, IAM, MFA et gestion des identités, Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « Ivanti Connect Secure contains an authentication bypass by spoofing vulnerability that allows a remote unauthenticated attacker to execute arbitrary commands. Ajoutée au catalogue KEV le 2026-10-13 (exploitation active confirmée par la CISA). Action requise (CISA) : Apply mitigations in accordance with vendor instructions, ensuring compliance with […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Ivanti, Connect Secure

[Donnée vérifiée] CVE : CVE-2026-104935 — CVSS 8.6 (HIGH, NVD (3c1d8aa1-5a33-4ea4-8992-aadd6440af75, Secondary)), EPSS 0.87, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Ivanti, Connect Secure.

[Analyse] Priorité : Modérée — Score 70 = 20 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si Ivanti, Connect Secure est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : Ivanti, Connect Secure.

[Modérée] Vulnérabilité dans Ivanti Connect Secure (ICS) (14 octobre 2026)

https://www.cert.cyber.gouv.fr/alerte/CERTFR-2026-ALE-013/

Source : CERT-FR — Alertes de sécurité — publié le 2026-10-14, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif — mots-clés : vulnérabilit, CVE, exécution de code, contournement, élévation de privilèges

[Fait] Résumé : Une vulnérabilité a été découverte dans Ivanti Connect Secure (ICS). Elle permet à un attaquant de provoquer une exécution de code arbitraire à distance, une élévation de privilèges et un contournement de la politique de sécurité. Ivanti indique que cette vulnérabilité CVE-2026-104935 est...

Produits cités : Ivanti, Connect Secure

[Donnée vérifiée] CVE : CVE-2026-104935 — CVSS 8.6 (HIGH, NVD (3c1d8aa1-5a33-4ea4-8992-aadd6440af75, Secondary)), EPSS 0.87, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Ivanti, Connect Secure.

[Analyse] Priorité : Modérée — Score 70 = 20 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Urgence) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si Ivanti, Connect Secure est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : elevee

[À vérifier] : Présence éventuelle dans le parc à confirmer : Ivanti, Connect Secure.

[Modérée] Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant

https://unit42.paloaltonetworks.com/fortimanager-cve-2024-47575-peerstitch-malware/

Source : Palo Alto Networks — Unit 42 — publié le 2026-10-14, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque, Vulnérabilité ou correctif — mots-clés : malware, attackers, CVE, exploited

[Analyse] Résumé : Menace ou campagne d'attaque — publication de Palo Alto Networks — Unit 42 du 2026-10-14. CVE citées : CVE-2024-47575. Score CVSS le plus élevé (NVD) : 9.8 (CVE-2024-47575). Produits cités : FortiGate, FortiManager. Exploitation active confirmée (catalogue CISA KEV). Extrait original (en) : « We investigated an intrusion where attackers exploited CVE-2024-47575 to target 500+ firewalls and deploy PEERSTITCH, a memory-resident ARM64 malware. The post Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant appeared first on Unit 42. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : FortiGate, FortiManager

[Donnée vérifiée] CVE : CVE-2024-47575 — CVSS 9.8 (CRITICAL, NVD (nvd@nist.gov, Primary)), EPSS 0.95, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : FortiGate, FortiManager.

[Analyse] Priorité : Modérée — Score 70 = 30 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si FortiGate, FortiManager est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Présence éventuelle dans le parc à confirmer : FortiGate, FortiManager. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

93 autres vulnérabilités sont référencées en annexe.

Menaces, campagnes et incidents

[Élevée] AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise

https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

Source : Microsoft Security Blog — publié le 2026-10-21, consulté le 2026-10-29

Catégorie : Évolution technologique, Menace ou campagne d'attaque — mots-clés : AI, agentic, supply chain, campaign

[Analyse] Résumé : Évolution technologique — publication de Microsoft Security Blog du 2026-10-21. Produits cités : Microsoft, ConnectWise. Technologies du parc concernées : Microsoft 365 (Exchange Online, Teams, SharePoint). Thèmes : Intelligence artificielle et IA générative, Machine learning appliqué à la cybersécurité, Sécurité du cloud, des conteneurs et de la chaîne logicielle. Extrait original (en) : « Storm-0940 used ARTEX agentic AI to accelerate a ConnectWise supply chain compromise, enabling application credential abuse across Microsoft 365 environments. The post AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise appeared first on Microsoft Security Blog. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Microsoft 365 (Exchange Online, Teams, SharePoint) (exposition : internet, criticité : elevee, versions du parc : n.c.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité, Intégrité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Microsoft 365 (Exchange Online, Teams, SharePoint).

[Analyse] Priorité : Élevée — Score 66 = 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) + 10 (Scénario redouté) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (4) Mettre à jour l'analyse du scénario redouté « Compromission de messagerie Microsoft 365 par hameçonnage » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : faible

[À vérifier] : Versions affectées de Microsoft 365 (Exchange Online, Teams, SharePoint) à comparer avec les versions du parc (non renseignées). Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Élevée] Agents are your newest insiders. Security must move at their speed.

https://www.microsoft.com/en-us/security/blog/2026/10/19/agents-are-your-newest-insiders-security-must-move-at-their-speed/

Source : Microsoft Security Blog — publié le 2026-10-19, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque

[Analyse] Résumé : Menace ou campagne d'attaque — publication de Microsoft Security Blog du 2026-10-19. Produits cités : Microsoft. Technologies du parc concernées : Microsoft 365 (Exchange Online, Teams, SharePoint). Extrait original (en) : « New capabilities in Microsoft 365 E7 and Project Perception help organizations contain agent risk and adapt protection continuously. The post Agents are your newest insiders. Security must move at their speed. appeared first on Microsoft Security Blog. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Microsoft 365 (Exchange Online, Teams, SharePoint) (exposition : internet, criticité : elevee, versions du parc : n.c.)

Exploitation : Aucune information d'exploitation

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Microsoft 365 (Exchange Online, Teams, SharePoint).

[Analyse] Priorité : Élevée — Score 56 = 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Compromission de messagerie Microsoft 365 par hameçonnage » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : faible

[À vérifier] : Versions affectées de Microsoft 365 (Exchange Online, Teams, SharePoint) à comparer avec les versions du parc (non renseignées). Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Élevée] Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware

https://thehackernews.com/2026/10/attackers-use-microsoft-teams-it.html

Source : The Hacker News — publié le 2026-10-26, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque — mots-clés : ransomware, threat actor, malware, attackers, scam, social engineering

[Analyse] Résumé : Menace ou campagne d'attaque — publication de The Hacker News du 2026-10-26. Produits cités : Microsoft, Teams. Technologies du parc concernées : Microsoft 365 (Exchange Online, Teams, SharePoint). Extrait original (en) : « Cybersecurity researchers are calling attention to what they say is a "recurring social engineering pattern" across hundreds of cases in which threat actors use Microsoft Teams' external chat creation feature to conduct impersonation scams or to deliver malware. "A consistent pattern of attacker behavior has emerged across these incidents: the use […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Microsoft 365 (Exchange Online, Teams, SharePoint) (exposition : internet, criticité : elevee, versions du parc : n.c.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Microsoft 365 (Exchange Online, Teams, SharePoint).

[Analyse] Priorité : Élevée — Score 56 = 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Informer les utilisateurs du mode opératoire décrit (message de sensibilisation ciblé). (3) Vérifier l'existence de sauvegardes hors ligne et tester une restauration. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (5) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : faible

[À vérifier] : Versions affectées de Microsoft 365 (Exchange Online, Teams, SharePoint) à comparer avec les versions du parc (non renseignées). Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[À qualifier] Compromised TLS Certificates

https://www.schneier.com/blog/archives/2026/10/compromised-tls-certificates.html

Source : Schneier on Security — publié le 2026-10-23, consulté le 2026-10-29

Catégorie : Évolution technologique, Incident ou retour d'expérience — mots-clés : cryptograph, incident, compromised, NIST Cybersecurity Framework 2.0

[Analyse] Résumé : Évolution technologique — publication de Schneier on Security du 2026-10-23. Thèmes : Cryptographie, post-quantique et gestion des secrets. Extrait original (en) : « The Indian CA eMudhra Limited has eight TLS certificates with laughably weak private keys: The compromised eMudhra keys were defective at a level that’s challenging the imagination of many of the engineers studying the incident. A normal size for a NIST P-384 elliptic curve cryptography private key contains roughly 384 bits of entropy, a size […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Pertinence : a_qualifier — Applicabilité du texte à qualifier.

[Analyse] Priorité : À qualifier — Score 8 = 8 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : a_qualifier.

[Recommandation] : (1) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Qualification requise (sous 7 jours)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Modérée] Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant

https://unit42.paloaltonetworks.com/fortimanager-cve-2024-47575-peerstitch-malware/

Source : Palo Alto Networks — Unit 42 — publié le 2026-10-14, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque, Vulnérabilité ou correctif — mots-clés : malware, attackers, CVE, exploited

[Analyse] Résumé : Menace ou campagne d'attaque — publication de Palo Alto Networks — Unit 42 du 2026-10-14. CVE citées : CVE-2024-47575. Score CVSS le plus élevé (NVD) : 9.8 (CVE-2024-47575). Produits cités : FortiGate, FortiManager. Exploitation active confirmée (catalogue CISA KEV). Extrait original (en) : « We investigated an intrusion where attackers exploited CVE-2024-47575 to target 500+ firewalls and deploy PEERSTITCH, a memory-resident ARM64 malware. The post Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant appeared first on Unit 42. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : FortiGate, FortiManager

[Donnée vérifiée] CVE : CVE-2024-47575 — CVSS 9.8 (CRITICAL, NVD (nvd@nist.gov, Primary)), EPSS 0.95, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : FortiGate, FortiManager.

[Analyse] Priorité : Modérée — Score 70 = 30 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si FortiGate, FortiManager est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Présence éventuelle dans le parc à confirmer : FortiGate, FortiManager. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Modérée] Adobe Commerce PolyShell Attacks Breach Hundreds of Stores as Brotli Exploit Traffic Emerges

https://thehackernews.com/2026/10/adobe-commerce-polyshell-attacks-breach.html

Source : The Hacker News — publié le 2026-10-28, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif, Incident ou retour d'expérience — mots-clés : vulnerabilit, CVE, KEV, exploited, exploitation, breach

[Analyse] Résumé : Vulnérabilité ou correctif — publication de The Hacker News du 2026-10-28. CVE citées : CVE-2026-111497. Score CVSS le plus élevé (NVD) : 9.2 (CVE-2026-111497). Produits cités : Adobe, Brotli. Exploitation active confirmée (catalogue CISA KEV). Extrait original (en) : « The U.S. Cybersecurity and Infrastructure Security Agency (CISA) on Tuesday added two vulnerabilities impacting Adobe Commerce and Magento, and Google's Brotli decoder library to its Known Exploited Vulnerabilities (KEV) catalog, citing evidence of active exploitation. The vulnerabilities are listed below - CVE-2026-111497 (CVSS score: 9.2) - An […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Adobe, Brotli

[Donnée vérifiée] CVE : CVE-2026-111497 — CVSS 9.2 (CRITICAL, NVD (cve-coordination@google.com, Secondary)), EPSS 0.83, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : Adobe, Brotli.

[Analyse] Priorité : Modérée — Score 70 = 30 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si Adobe, Brotli est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Présence éventuelle dans le parc à confirmer : Adobe, Brotli. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Modérée] Active Exploitation of May 2026 PAN-OS CVE-2026-0257 (Updated October 20)

https://unit42.paloaltonetworks.com/active-exploitation-of-pan-os-cve-2026-0257/

Source : Palo Alto Networks — Unit 42 — publié le 2026-10-20, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif, Menace ou campagne d'attaque — mots-clés : vulnerabilit, CVE, exploitation, ransomware

[Analyse] Résumé : Vulnérabilité ou correctif — publication de Palo Alto Networks — Unit 42 du 2026-10-20. CVE citées : CVE-2026-0257. Produits cités : PAN-OS. Exploitation active confirmée (catalogue CISA KEV). Extrait original (en) : « Ransomware operators including Spikey Scorpius (aka Qilin) and Tarnished Scorpius (aka Inc) are exploiting PAN-OS vulnerability CVE-2026-0257. The post Active Exploitation of May 2026 PAN-OS CVE-2026-0257 (Updated October 20) appeared first on Unit 42. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : PAN-OS

[Donnée vérifiée] CVE : CVE-2026-0257 — CVSS non disponible, EPSS 0.95, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Intégrité, Disponibilité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : PAN-OS.

[Analyse] Priorité : Modérée — Score 55 = 30 (Exploitation active) + 5 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si PAN-OS est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (3) Vérifier l'existence de sauvegardes hors ligne et tester une restauration. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (5) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Score CVSS de CVE-2026-0257 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Présence éventuelle dans le parc à confirmer : PAN-OS. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Modérée] Threat Brief: Critical Vulnerabilities in PHP: CVE-2026-109618, CVE-2026-109619 (Updated October 29)

https://unit42.paloaltonetworks.com/cve-2026-109618-cve-2026-109619/

Source : Palo Alto Networks — Unit 42 — publié le 2026-10-29, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque, Vulnérabilité ou correctif — mots-clés : threat brief, vulnerabilit, CVE

[Analyse] Résumé : Menace ou campagne d'attaque — publication de Palo Alto Networks — Unit 42 du 2026-10-29. CVE citées : CVE-2026-109618, CVE-2026-109619. Produits cités : PHP. Exploitation active confirmée (catalogue CISA KEV). Extrait original (en) : « CVE-2026-109618 and CVE-2026-109619 are Critical vulnerabilities in PHP, a scripting language used globally for web servers and CMS systems. The post Threat Brief: Critical Vulnerabilities in PHP: CVE-2026-109618, CVE-2026-109619 (Updated October 29) appeared first on Unit 42. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : PHP

[Donnée vérifiée] CVE : CVE-2026-109618 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée; CVE-2026-109619 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : PHP.

[Analyse] Priorité : Modérée — Score 52 = 12 (Gravité technique) + 30 (Exploitation active) + 10 (Probabilité d'exploitation) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si PHP est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Score CVSS de CVE-2026-109618 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Score CVSS de CVE-2026-109619 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Présence éventuelle dans le parc à confirmer : PHP. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Modérée] Amazon Threat Intelligence identifies PHP2Shell exploitation prior to public disclosure in MadPot

https://aws.amazon.com/blogs/security/amazon-threat-intelligence-identifies-php2shell-exploitation-prior-to-public-disclosure-in-madpot/

Source : AWS Security Blog — publié le 2026-10-21, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif, Menace ou campagne d'attaque, Évolution technologique — mots-clés : vulnerabilit, CVE, exploitation, threat intelligence

[Analyse] Résumé : Vulnérabilité ou correctif — publication de AWS Security Blog du 2026-10-21. CVE citées : CVE-2026-109618, CVE-2026-109619. Produits cités : PHP. Exploitation active confirmée (catalogue CISA KEV). Thèmes : SIEM, EDR, XDR, détection et réponse aux incidents, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « Amazon Threat Intelligence identified a PHP2Shell exploitation attempt dating to Oct. 17, 2026, in MadPot telemetry, four days before public disclosure of CVE-2026-109618 and CVE-2026-109619. The exploit attempt originated from an IP address associated with a commercial anonymization network. While the vulnerability was under embargo, the […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : PHP

[Donnée vérifiée] CVE : CVE-2026-109618 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée; CVE-2026-109619 — CVSS non disponible, EPSS 1.00, KEV : exploitation active confirmée

Exploitation : Exploitation active confirmée (catalogue CISA KEV) (vérifié)

[Analyse] Impact potentiel : Confidentialité

[Analyse] Pertinence : faible — Produits cités absents de l'inventaire déclaré : PHP.

[Analyse] Priorité : Modérée — Score 50 = 30 (Exploitation active) + 10 (Probabilité d'exploitation) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : faible. Pertinence faible (aucun lien établi avec le parc ou le profil) : niveau plafonné à « Modérée » ; vérifier que l'inventaire est complet.

[Recommandation] : (1) Vérifier si PHP est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (3) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Score CVSS de CVE-2026-109618 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Score CVSS de CVE-2026-109619 non disponible (NVD non encore interrogé) : ne pas l'estimer, consulter l'avis éditeur. Présence éventuelle dans le parc à confirmer : PHP. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Modérée] Attackers Exploit Second Cisco Firewall VPN Zero-Day Since August

https://www.securityweek.com/attackers-exploit-second-cisco-firewall-vpn-zero-day-since-august/

Source : SecurityWeek — publié le 2026-10-29, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif, Menace ou campagne d'attaque — mots-clés : flaw, zero-day, exploited, attackers

[Analyse] Résumé : Vulnérabilité ou correctif — publication de SecurityWeek du 2026-10-29. Produits cités : Cisco. Technologies du parc concernées : Pare-feu et VPN SSL (géré par l'infogérant). Extrait original (en) : « An exploited flaw in the Remote Access SSL VPN service lets unauthenticated attackers remotely force ASA and FTD firewalls to reload. The post Attackers Exploit Second Cisco Firewall VPN Zero-Day Since August appeared first on SecurityWeek. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Pare-feu et VPN SSL (géré par l'infogérant) (exposition : internet, criticité : critique, versions du parc : n.c.)

Exploitation : Aucune information d'exploitation

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Pare-feu et VPN SSL (géré par l'infogérant).

[Analyse] Priorité : Modérée — Score 45 = 10 (Présence dans le parc) + 15 (Exposition) + 10 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire. (2) Vérifier la présence et les versions de Pare-feu et VPN SSL (géré par l'infogérant) concernées par l'avis (inventaire, outil de gestion de parc). (3) Demander à l'infogérant l'application du correctif sur Pare-feu et VPN SSL (géré par l'infogérant) et une confirmation écrite (modèle, version, date), à conserver comme preuve. (4) En attendant le correctif, réduire l'exposition (filtrage des accès, désactivation de la fonctionnalité vulnérable) selon les recommandations de l'éditeur. (5) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (6) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (7) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Marque et modèle de « Pare-feu et VPN SSL (géré par l'infogérant) » non documentés : confirmer auprès du gestionnaire si l'avis s'applique. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

8. Évolutions technologiques pertinentes

Thème	Éléments	Surveillé
Intelligence artificielle et IA générative	73	oui
Sécurité du cloud, des conteneurs et de la chaîne logicielle	51	oui
Zero Trust, IAM, MFA et gestion des identités	17	oui
SIEM, EDR, XDR, détection et réponse aux incidents	15	oui
Cryptographie, post-quantique et gestion des secrets	14	non
DevSecOps, SBOM et sécurité des dépendances	11	non
Machine learning appliqué à la cybersécurité	8	non
Nouvelles méthodes de détection, de prévention et de remédiation	7	oui
Sécurité de la messagerie et lutte contre l'hameçonnage	4	oui
Automatisation de la sécurité et SOAR	4	non
Sauvegarde, restauration et continuité d'activité	2	oui

AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise

https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

Source : Microsoft Security Blog — publié le 2026-10-21, consulté le 2026-10-29

Catégorie : Évolution technologique, Menace ou campagne d'attaque — mots-clés : AI, agentic, supply chain, campaign

[Analyse] Résumé : Évolution technologique — publication de Microsoft Security Blog du 2026-10-21. Produits cités : Microsoft, ConnectWise. Technologies du parc concernées : Microsoft 365 (Exchange Online, Teams, SharePoint). Thèmes : Intelligence artificielle et IA générative, Machine learning appliqué à la cybersécurité, Sécurité du cloud, des conteneurs et de la chaîne logicielle. Extrait original (en) : « Storm-0940 used ARTEX agentic AI to accelerate a ConnectWise supply chain compromise, enabling application credential abuse across Microsoft 365 environments. The post AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise appeared first on Microsoft Security Blog. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Microsoft 365 (Exchange Online, Teams, SharePoint) (exposition : internet, criticité : elevee, versions du parc : n.c.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité, Intégrité

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Microsoft 365 (Exchange Online, Teams, SharePoint).

[Analyse] Priorité : Élevée — Score 66 = 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) + 10 (Scénario redouté) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (4) Mettre à jour l'analyse du scénario redouté « Compromission de messagerie Microsoft 365 par hameçonnage » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : faible

[À vérifier] : Versions affectées de Microsoft 365 (Exchange Online, Teams, SharePoint) à comparer avec les versions du parc (non renseignées). Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

Microsoft urges Entra ID admins to migrate users to passkeys

https://www.bleepingcomputer.com/news/microsoft/microsoft-reminds-entra-id-admins-to-migrate-users-to-passkeys/

Source : BleepingComputer — publié le 2026-10-28, consulté le 2026-10-29

Catégorie : Évolution technologique — mots-clés : passkey, authentication

[Analyse] Résumé : Évolution technologique — publication de BleepingComputer du 2026-10-28. Produits cités : Microsoft, Entra ID. Technologies du parc concernées : Microsoft Entra ID. Thèmes : Zero Trust, IAM, MFA et gestion des identités, Sécurité de la messagerie et lutte contre l'hameçonnage. Extrait original (en) : « Microsoft again asked Entra ID administrators to migrate users to phishing-resistant methods to avoid sign-in disruptions before it retires SMS and voice authentication in February 2027. [...] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Microsoft Entra ID (exposition : internet, criticité : critique, versions du parc : n.c.)

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Microsoft Entra ID.

[Analyse] Priorité : Élevée — Score 60 = 25 (Présence dans le parc) + 15 (Exposition) + 10 (Impact sur les activités) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Forte (sous 7 jours)

Confiance de l'analyse : faible

[À vérifier] : Versions affectées de Microsoft Entra ID à comparer avec les versions du parc (non renseignées). Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

Managing identity source transition for AWS IAM Identity Center

https://aws.amazon.com/blogs/security/managing-identity-source-transition-for-aws-iam-identity-center/

Source : AWS Security Blog — publié le 2026-10-20, consulté le 2026-10-29

Catégorie : Évolution technologique — mots-clés : identity, IAM, automation

[Analyse] Résumé : Évolution technologique — publication de AWS Security Blog du 2026-10-20. Produits cités : Active Directory. Technologies du parc concernées : Active Directory (corp.aerostar.lan). Thèmes : Automatisation de la sécurité et SOAR, Zero Trust, IAM, MFA et gestion des identités, Sécurité du cloud, des conteneurs et de la chaîne logicielle. Extrait original (en) : « October 20, 2026: This post was republished to reflect the new migration capability from Active Directory to an external identity provider (IdP) or the Identity Center directory, now available in IAM Identity Center. September 2, 2026: This post was republished to include Active Directory migration strategies and automation for permission sets. […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Parc concerné : Active Directory (corp.aerostar.lan) (exposition : interne, criticité : critique, versions du parc : n.c.)

[Analyse] Pertinence : forte — Technologie(s) du parc citée(s) : Active Directory (corp.aerostar.lan).

[Analyse] Priorité : Modérée — Score 45 = 25 (Présence dans le parc) + 10 (Impact sur les activités) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Versions affectées de Active Directory (corp.aerostar.lan) à comparer avec les versions du parc (non renseignées). Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

Chainalysis discloses data breach from "offensive agentic techniques"

https://www.bleepingcomputer.com/news/security/chainalysis-discloses-data-breach-from-offensive-agentic-techniques/

Source : BleepingComputer — publié le 2026-10-31, consulté le 2026-10-31

Catégorie : Incident ou retour d'expérience, Évolution technologique — mots-clés : data breach, breach, agentic, RGPD

[Analyse] Résumé : Incident ou retour d'expérience — publication de BleepingComputer du 2026-10-31. Thèmes : Intelligence artificielle et IA générative. Extrait original (en) : « Blockchain analytics firm Chainalysis disclosed a data breach after attackers used "offensive agentic techniques" to access internal systems and tools, exposing customer names, email addresses, user IDs, and organizational roles. […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 40 = 30 (Importance réglementaire / normative) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

Managing AI Token Consumption for Operational Resilience

https://www.cisa.gov/resources-tools/resources/managing-ai-token-consumption-operational-resilience

Source : CISA — Cybersecurity Advisories — publié le 2026-10-22, consulté le 2026-10-29

Catégorie : Évolution technologique, Incident ou retour d'expérience, Vulnérabilité ou correctif — mots-clés : AI, incident, outage

[Analyse] Résumé : Évolution technologique — publication de CISA — Cybersecurity Advisories du 2026-10-22. Thèmes : Intelligence artificielle et IA générative, Sauvegarde, restauration et continuité d'activité. Extrait original (en) : « CISA, the Canadian Centre for Cyber Security (Cyber Centre), and partners are releasing joint guidance, Managing AI Token Consumption for Operational Resilience, to help organizations understand and manage token usage in support of operations. As organizations adopt third-party super intelligence (SI) services, token-based usage models can affect […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Disponibilité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative, Sauvegarde, restauration et continuité d'activité.

[Analyse] Priorité : Modérée — Score 30 = 12 (Gravité technique) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

⚡ Weekly Recap: This2Shell, That2Shell, Everything's an RCE? Rogue AI, Supply Chain Chaos and More

https://thehackernews.com/2026/10/weekly-recap-this2shell-that2shell.html

Source : The Hacker News — publié le 2026-10-26, consulté le 2026-10-29

Catégorie : Vulnérabilité ou correctif, Évolution technologique, Menace ou campagne d'attaque — mots-clés : flaw, patch, RCE, AI, supply chain, attackers, hackers

[Analyse] Résumé : Vulnérabilité ou correctif — publication de The Hacker News du 2026-10-26. Produits cités : Teams. Thèmes : Intelligence artificielle et IA générative, Sécurité du cloud, des conteneurs et de la chaîne logicielle. Extrait original (en) : « This2Shell, That2Shell, Everything2Shell. That's pretty much how the last week went. Critical bugs that let attackers run code remotely are showing up everywhere. Hackers are scanning for targets, some flaws are already being used in attacks, and security teams have more urgent patches than they can keep up with. And that's not even the full […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Teams

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité, Intégrité

[Analyse] Pertinence : moyenne — Menace ou pratique générique, potentiellement transposable au SI de l'organisation.

[Analyse] Priorité : Modérée — Score 30 = 12 (Gravité technique) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier si Teams est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. (2) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (3) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Présence éventuelle dans le parc à confirmer : Teams. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

VAPOR PANDA Uses AI-Driven ARTEX to Scale a Global Espionage Campaign

https://www.crowdstrike.com/en-us/blog/vapor-panda-uses-artex-to-scale-global-campaign/

Source : CrowdStrike Blog — publié le n.c., consulté le 2026-10-31

Catégorie : Menace ou campagne d'attaque, Évolution technologique — mots-clés : campaign, espionage, AI

[Analyse] Résumé : Menace ou campagne d'attaque — publication de CrowdStrike Blog (date de publication non fournie). Thèmes : Intelligence artificielle et IA générative, Machine learning appliqué à la cybersécurité. (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative.

[Analyse] Priorité : Modérée — Score 28 = 10 (Scénario redouté) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (4) Mettre à jour l'analyse du scénario redouté « Fuite ou vol de plans et maquettes clients » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité). Résumé de la source très court : analyse fondée essentiellement sur le titre, consulter l'article.

Evolution of Web3 in Cloud Supply Chain Attacks

https://unit42.paloaltonetworks.com/web3-cloud-supply-chain-attacks/

Source : Palo Alto Networks — Unit 42 — publié le 2026-10-07, consulté le 2026-10-29

Catégorie : Évolution technologique, Menace ou campagne d'attaque — mots-clés : cloud, supply chain, threat actor

[Analyse] Résumé : Évolution technologique — publication de Palo Alto Networks — Unit 42 du 2026-10-07. Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle. Extrait original (en) : « Unit 42 details how threat actors leverage Web3 infrastructure and open-source supply chain attacks to breach enterprise cloud environments The post Evolution of Web3 in Cloud Supply Chain Attacks appeared first on Unit 42. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Intégrité

[Analyse] Pertinence : moyenne — Thème surveillé : Sécurité du cloud, des conteneurs et de la chaîne logicielle.

[Analyse] Priorité : Modérée — Score 28 = 10 (Scénario redouté) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (4) Mettre à jour l'analyse du scénario redouté « Fuite ou vol de plans et maquettes clients » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

“Next Exploit Opportunities”: How a Threat Actor Used AI to Help Plan and Execute Multiple Types of Cybercrime Activities

https://unit42.paloaltonetworks.com/ai-assisted-cybercrime-analysis/

Source : Palo Alto Networks — Unit 42 — publié le 2026-10-21, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque, Évolution technologique — mots-clés : threat actor, fraud, AI

[Analyse] Résumé : Menace ou campagne d'attaque — publication de Palo Alto Networks — Unit 42 du 2026-10-21. Thèmes : Intelligence artificielle et IA générative. Extrait original (en) : « An investigation into a threat actor bypassing AI safety controls to coordinate credential theft, VoIP fraud planning, and database exfiltration. The post “Next Exploit Opportunities”: How a Threat Actor Used AI to Help Plan and Execute Multiple Types of Cybercrime Activities appeared first on Unit 42. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité, Intégrité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative.

[Analyse] Priorité : Modérée — Score 28 = 10 (Scénario redouté) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (4) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks

https://www.microsoft.com/en-us/security/blog/2026/10/23/inside-the-litellm-1-107-0-supply-chain-compromise-credential-theft-through-python-startup-hooks/

Source : Microsoft Security Blog — publié le 2026-10-23, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque, Évolution technologique — mots-clés : threat intelligence, supply chain

[Analyse] Résumé : Menace ou campagne d'attaque — publication de Microsoft Security Blog du 2026-10-23. Produits cités : Microsoft, Python. Thèmes : SIEM, EDR, XDR, détection et réponse aux incidents, Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation. Extrait original (en) : « Microsoft Threat Intelligence analyzes the LiteLLM 1.107.0 compromise, including Python startup hooks, credential theft, remote code loading, detections, and mitigations. The post Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks appeared first on Microsoft Security Blog. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Produits cités : Microsoft, Python

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité, Intégrité

[Analyse] Pertinence : moyenne — Thème surveillé : SIEM, EDR, XDR, détection et réponse aux incidents, Sécurité du cloud, des conteneurs et de la chaîne logicielle, Nouvelles méthodes de détection, de prévention et de remédiation.

[Analyse] Priorité : Modérée — Score 28 = 10 (Scénario redouté) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (4) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Présence éventuelle dans le parc à confirmer : Microsoft, Python. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

AI-Generated Fake Login Pages Are Making Account Takeovers Easier

https://thehackernews.com/2026/10/ai-generated-fake-login-pages-are.html

Source : The Hacker News — publié le 2026-10-27, consulté le 2026-10-29

Catégorie : Évolution technologique, Menace ou campagne d'attaque — mots-clés : AI, generative, MFA, phishing, attackers

[Analyse] Résumé : Évolution technologique — publication de The Hacker News du 2026-10-27. Thèmes : Intelligence artificielle et IA générative, Zero Trust, IAM, MFA et gestion des identités, Sécurité de la messagerie et lutte contre l'hameçonnage. Extrait original (en) : « Fake login pages are nothing new, but generative AI is making them easier to build and more convincing. Attackers can recreate familiar login screens, impersonate trusted brands and tailor phishing attempts to specific employees or organizations. Some fake login pages go beyond stealing passwords. They can also capture MFA codes or hijack […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative, Zero Trust, IAM, MFA et gestion des identités, Sécurité de la messagerie et lutte contre l'hameçonnage.

[Analyse] Priorité : Modérée — Score 28 = 10 (Scénario redouté) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Informer les utilisateurs du mode opératoire décrit (message de sensibilisation ciblé). (3) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (5) Mettre à jour l'analyse du scénario redouté « Compromission de messagerie Microsoft 365 par hameçonnage » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

American Organizations Under Attack: Skyw4lker Device Code Phishing Campaign Exposed

https://thehackernews.com/2026/10/american-organizations-under-attack.html

Source : The Hacker News — publié le 2026-10-28, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque, Évolution technologique, Incident ou retour d'expérience — mots-clés : campaign, phishing, attackers, cloud, authentication, exposed

[Analyse] Résumé : Menace ou campagne d'attaque — publication de The Hacker News du 2026-10-28. Thèmes : Zero Trust, IAM, MFA et gestion des identités, Sécurité du cloud, des conteneurs et de la chaîne logicielle, Sécurité de la messagerie et lutte contre l'hameçonnage. Extrait original (en) : « Modern phishing campaigns can compromise American businesses without relying on traditional credential theft. Attackers can abuse legitimate cloud services, authentication mechanisms, and trusted business workflows to gain access to corporate accounts while leaving fewer obvious signs behind. ANY.RUN's analysis of Skyw4lker, a device code phishing […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Confidentialité

[Analyse] Pertinence : moyenne — Thème surveillé : Zero Trust, IAM, MFA et gestion des identités, Sécurité du cloud, des conteneurs et de la chaîne logicielle, Sécurité de la messagerie et lutte contre l'hameçonnage.

[Analyse] Priorité : Modérée — Score 28 = 10 (Scénario redouté) + 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Informer les utilisateurs du mode opératoire décrit (message de sensibilisation ciblé). (3) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (4) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (5) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (6) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

9. Veille réglementaire

Textes surveillés et orientation d'applicabilité

Orientation calculée à partir du profil déclaré : elle ne constitue pas un avis juridique et doit être confirmée par le juriste ou le DPO. Statuts et dates issus du référentiel de configuration (vérifié le indiqué), à revérifier sur les sources officielles.

Texte	Nature	Statut (référentiel)	Applicabilité (orientation)	Motif
RGPD — Règlement général sur la protection des données	Obligation légale (texte contraignant)	Applicable	Applicabilité probable — à confirmer	L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée).
NIS 2 — Directive sur la sécurité des réseaux et des systèmes d'information	Obligation légale (texte contraignant)	Adopté (UE) — transposition nationale à vérifier	Applicabilité à qualifier	Filière aéronautique : la fabrication de matériels de transport relève de l'annexe II, mais un bureau d'études n'y est a priori pas visé directement ; ses clients peuvent l'être et répercuter leurs obligations (sécurité de la chaîne d'approvisionnement). À qualifier avec le simulateur de l'ANSSI. L'organisation a déclaré cette exigence (à confirmer).
DORA — Résilience opérationnelle numérique du secteur financier	Obligation légale (texte contraignant)	Applicable	Applicabilité peu probable en l'état des informations	Organisation non financière et pas de rôle de prestataire TIC du secteur financier déclaré.
AI Act — Règlement européen sur l'intelligence artificielle	Obligation légale (texte contraignant)	Application progressive	Applicabilité à qualifier	Usages d'IA non déclarés : l'utilisation d'outils d'IA générative par les salariés suffit à faire de l'organisation un déployeur.
CRA — Règlement sur la cyberrésilience	Obligation légale (texte contraignant)	Application progressive	Applicabilité peu probable en l'état des informations	Aucune activité d'édition logicielle ou de fabrication de produits numériques déclarée ; impact indirect via les fournisseurs (SBOM, support).
eIDAS 2 — Identité numérique européenne et services de confiance	Obligation légale (texte contraignant)	Application progressive	Applicabilité peu probable en l'état des informations	Pas de rôle de prestataire de services de confiance déclaré ; usage possible de la signature électronique à vérifier.
Dispositif OIV (loi de programmation militaire)	Obligation légale (texte contraignant)	Applicable	Applicabilité peu probable en l'état des informations	Aucune désignation OIV déclarée (une désignation fait l'objet d'une notification de l'État).
Certification Hébergeur de Données de Santé (HDS)	Obligation légale (texte contraignant)	Applicable	Applicabilité peu probable en l'état des informations	Aucun traitement de données de santé déclaré.
Contrôle des exportations de biens à double usage	Obligation légale (texte contraignant)	Applicable	Applicabilité à qualifier	Des données techniques potentiellement soumises au contrôle sont traitées : vérification projet par projet. L'organisation a déclaré cette exigence (à confirmer).
Part-IS — Sécurité de l'information dans l'aviation (EASA)	Obligation légale (texte contraignant)	Application progressive	Impact indirect probable (clients, contrats)	Sous-traitant d'organismes agréés : exigences de sécurité de l'information répercutées possibles.

Évolutions détectées sur la période

[Modérée] Dutch DPA fines Uber EUR 824 990 000 for unlawful automated decision-making and insufficient information on profiling

https://www.edpb.europa.eu/news/dutch-dpa-fines-uber-eur-824-990-000-for-unlawful-automated-decision-making-and-insufficient_en

Source : EDPB — Actualités — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : regulation, fine , fines , fined, CNIL, GDPR, data protection, legal

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-08. Extrait original (en) : « Background information Cross-border case Controller: Uber B.V Legal Reference(s): Article 22 (Automated individual decision making, including profiling) and Article 13 (Information to be provided where personal data are collected from the data subject) Decision: Administrative fine Key words: Automated decision making, profiling and online […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Hellenic DPA decision on a data breach involving E.E.T.A.A. S.A. as processor for the Ministry of Social Cohesion and Family Affairs

https://www.edpb.europa.eu/news/hellenic-dpa-decision-on-a-data-breach-involving-eetaa-sa-as-processor-for-the-ministry-of_en

Source : EDPB — Actualités — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Évolution réglementaire, Incident ou retour d'expérience — mots-clés : fine , fines , compliance, GDPR, data protection, legal, supervisory authority, incident

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-08. Extrait original (en) : « Background information Date of final decision: 28/07/2026 National case Controller: Ministry of Social Cohesion and Family Affairs Legal Reference(s): Article 25 (Data protection by design and by default), Article 28 (Processor), Article 32 (Security of processing), Article 33 (Notification of a personal data breach to the supervisory authority) […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2026-07-28

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

Exploitation : Aucune information d'exploitation

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (2) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Swedish DPA fines Miljödata i Karlskrona approximately EUR 160 000 for insufficient technical and organisational measures to ensure information security

https://www.edpb.europa.eu/news/swedish-dpa-fines-miljodata-i-karlskrona-approximately-eur-160-000-for-insufficient-technical_en

Source : EDPB — Actualités — publié le 2026-10-08, consulté le 2026-10-29

Catégorie : Évolution réglementaire, Incident ou retour d'expérience — mots-clés : fine , fines , GDPR, data protection, legal, incident, data breach, breach

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-08. Thèmes : Zero Trust, IAM, MFA et gestion des identités. Extrait original (en) : « Background information Date of final decision: 22/09/2026 National case Legal Reference(s): Article 32 (Security of processing) Decision: Administrative fine Key words: Cybersecurity, personal data breaches Summary of the Decision Origin of the case In August 2025, the IT service provider Miljödata was targeted in a cyberattack, during which a […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2026-09-22

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

Exploitation : Aucune information d'exploitation

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (2) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Italian DPA fines BBVA EUR 5 508 000 for failing to respect a customer's objection to direct marketing

https://www.edpb.europa.eu/news/italian-dpa-fines-bbva-eur-5-508-000-for-failing-to-respect-a-customers-objection-to-direct_en

Source : EDPB — Actualités — publié le 2026-10-09, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : fine , fines , compliance, GDPR, data protection, legal, RGPD

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-09. Extrait original (en) : « Background information Date of final decision: 3 July 2026 National case Controller: Banco Bilbao Vizcaya Argentaria, S.A., Italian branch (BBVA) Legal Reference(s): Article 5 (Principles relating to processing of personal data), Article 12 (Transparent information, communication and modalities for the exercise of the rights of the data subject), […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2026-07-03

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Italian DPA fines Emirates EUR 180 000 for infringements concerning passengers' health data

https://www.edpb.europa.eu/news/italian-dpa-fines-emirates-eur-180-000-for-infringements-concerning-passengers-health-data_en

Source : EDPB — Actualités — publié le 2026-10-09, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : fine , fines , compliance, GDPR, data protection, legal, RGPD

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-09. Extrait original (en) : « Background information Date of final decision: 14 May 2026 National case Controller: Emirates Legal Reference(s): Article 5 (Principles relating to processing of personal data), Article 12 (Transparent information, communication and modalities for the exercise of the rights of the data subject) and Article 13 (Information to be provided where [...] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2026-05-14

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Italian DPA fines security company EUR 39 000 for violations concerning employees' data

https://www.edpb.europa.eu/news/italian-dpa-fines-security-company-eur-39-000-for-violations-concerning-employees-data_en

Source : EDPB — Actualités — publié le 2026-10-09, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : fine , fines , compliance, GDPR, data protection, legal, RGPD

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-09. Extrait original (en) : « Background information Date of final decision: 6 August 2026 National case Controller: La Patria S.p.A. Legal Reference(s): Article 12 (Transparent information, communication and modalities for the exercise of the rights of the data subject), Article 13 (Information to be provided where personal data are collected from the data subject) and [...] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2026-08-06

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Italian DPA fines IQVIA EUR 7 000 000 for unlawful processing of patients' health data

https://www.edpb.europa.eu/news/italian-dpa-fines-iqvia-eur-7-000-000-for-unlawful-processing-of-patients-health-data_en

Source : EDPB — Actualités — publié le 2026-10-09, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : fine , fines , compliance, GDPR, data protection, legal, RGPD

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-09. Extrait original (en) : « Background information Date of final decision: 23 September 2026 National case Controller: IQVIA Solutions Italy S.r.l Legal Reference(s): Article 5 (Principles relating to processing of personal data), Article 9 (Processing of special categories of personal data), Article 13 (Information to be provided where personal data are collected from the […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2026-09-23

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] EDPB publishes statement on the data protection challenges of smart glasses

https://www.edpb.europa.eu/news/edpb-publishes-statement-on-the-data-protection-challenges-of-smart-glasses_en

Source : EDPB — Actualités — publié le 2026-10-13, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : EDPB, GDPR, data protection, RGPD

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-13. Extrait original (en) : « Brussels, 13 October – During its latest plenary, the EDPB has adopted statement 1/2026 on smart glasses and published the report “The connected gaze. Video recording, surveillance and administering evidence in the age of smart glasses”*, developed in the context of the Support Pool of Expert (SPE) programme**. As smart glasses become widely […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Adoption

[Analyse] Statut juridique : Adopté (selon la source) — à confirmer

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Le CEPD publie une déclaration sur les enjeux de protection des données liés aux lunettes connectées

https://www.cnil.fr/fr/cepd-declaration-lunettes-connectees

Source : CNIL — Actualités — publié le 2026-10-13, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : protection des données, RGPD

[Fait] Résumé : Lors de sa dernière plénière, le CEPD a adopté une déclaration sur les lunettes connectées et publié le rapport intitulé « Le regard connecté. Une sociologie des usages et des défis liés aux lunettes connectées », élaboré dans le cadre du programme de réserve d’experts (Support Pool of Expert).

[Analyse] Nature de l'évolution : Adoption

[Analyse] Statut juridique : Adopté (selon la source) — à confirmer

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Clôture de l’injonction prononcée à l’encontre de GOOGLE

https://www.cnil.fr/fr/cloture-injonction-google

Source : CNIL — Actualités — publié le 2026-10-14, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : CNIL, RGPD

[Fait] Résumé : Par décision du 23 septembre 2026, la formation restreinte de la CNIL a clos l’injonction prononcée le 1er septembre 2025 à l’encontre des sociétés GOOGLE LLC et GOOGLE IRELAND LIMITED.

[Analyse] Nature de l'évolution : Évolution à qualifier

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2025-09-01, 2026-09-23

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Norwegian DPA fines Xandr EUR 8 600 000 for unlawful processing of personal data

https://www.edpb.europa.eu/news/norwegian-dpa-fines-xandr-eur-8-600-000-for-unlawful-processing-of-personal-data_en

Source : EDPB — Actualités — publié le 2026-10-16, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : fine , fines , fined, GDPR, data protection, legal, RGPD

[Analyse] Résumé : Évolution réglementaire — publication de EDPB — Actualités du 2026-10-16. Produits cités : Microsoft. Extrait original (en) : « Background information Date of final decision: 2 October 2026 National case Controller: Xandr Inc. Legal References: Article 6 (Lawfulness of processing), Article 9 (Processing of special categories of personal data) Decision: Administrative fine Key words: Fines, Basic principles, Marketing, Online platforms Summary of the Decision Origin of the […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Nature de l'évolution : Sanction ou décision d'une autorité

[Analyse] Statut juridique : À vérifier sur la source officielle

[Fait] Dates mentionnées par la source : 2026-10-02

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

Produits cités : Microsoft

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Modérée] Reconstitution d’adresses électroniques professionnelles : quels sont vos droits ?

https://www.cnil.fr/fr/reconstitution-adresses-professionnelles-vos-droits

Source : CNIL — Actualités — publié le 2026-10-16, consulté le 2026-10-29

Catégorie : Évolution réglementaire — mots-clés : CNIL, RGPD, données personnelles

[Fait] Résumé : Lorsque vos données personnelles sont accessibles sur Internet, elles peuvent être récupérées par des organismes pour reconstituer votre adresse électronique professionnelle, notamment pour faire de la prospection. La reconstitution d’adresse électronique doit respecter le RGPD afin d’être légale. La CNIL fait le point sur vos droits.

[Analyse] Nature de l'évolution : Évolution à qualifier

[Analyse] Statut juridique : À vérifier sur la source officielle

Texte concerné : RGPD — Règlement général sur la protection des données : Règlement (UE) 2016/679 — Obligation légale (texte contraignant) — Applicabilité probable — à confirmer. L'organisation déclare traiter des données à caractère personnel. L'organisation a déclaré cette exigence (identifiée). Organisations concernées : Tout organisme qui traite des données à caractère personnel (responsable de traitement ou sous-traitant) établi dans l'UE ou ciblant des personnes dans l'UE.

Obligations possibles (à vérifier) : Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35); Encadrement contractuel des sous-traitants (art. 28)

Démarches pour qualifier l'applicabilité : Vérifier dans le registre des traitements les données personnelles effectivement traitées; Qualifier le rôle de l'organisation (responsable de traitement, sous-traitant, responsable conjoint); Consulter le DPO sur l'impact de l'évolution détectée

[Analyse] Impact potentiel : RGPD — Règlement général sur la protection des données — Applicabilité probable — à confirmer

[Analyse] Pertinence : forte — Texte ou référentiel dont l'applicabilité est probable : RGPD — Règlement général sur la protection des données.

[Analyse] Priorité : Modérée — Score 30 = 30 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

[Recommandation] : (1) Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-30 — urgence : Normale (sous 30 jours)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

10. Veille normative

Distinction appliquée : une norme (ISO/IEC) ou un référentiel (NIST CSF) est d'application volontaire, une recommandation (ANSSI) n'est pas contraignante ; seuls un texte légal, un contrat ou une certification visée les rendent exigibles. Aucune recommandation n'est présentée comme une obligation légale.

Référentiel	Nature	Applicabilité (orientation)	Motif
PCI DSS — Sécurité des données de cartes de paiement	Exigence contractuelle	Applicabilité peu probable en l'état des informations	Aucune acceptation de paiement par carte déclarée.
ISO/IEC 27001 — Systèmes de management de la sécurité de l'information	Norme volontaire	Applicabilité à qualifier	Non exigé : retenu par l'organisation comme référentiel de bonnes pratiques et cible à long terme. (Non exigée ; référentiel de bonnes pratiques et cible à long terme)
ISO/IEC 27002 — Mesures de sécurité de l'information	Norme volontaire	Applicabilité à qualifier	Recommandations de mesures : non contraignantes en soi.
ISO/IEC 42001 — Système de management de l'IA	Norme volontaire	Applicabilité peu probable en l'état des informations	Aucun usage d'IA déclaré.
NIST Cybersecurity Framework 2.0	Référentiel de bonnes pratiques	Applicabilité à qualifier	Référentiel de bonnes pratiques volontaire.
Guide d'hygiène informatique de l'ANSSI et recommandations ANSSI	Recommandation (non contraignante)	Applicabilité à qualifier	Recommandations applicables à toute organisation, sans caractère obligatoire.
SecNumCloud — Référentiel de qualification des prestataires cloud	Référentiel de bonnes pratiques	Applicabilité peu probable en l'état des informations	Pas d'activité d'hébergement cloud pour des clients publics déclarée.
AirCyber — Référentiel de maturité cyber de la filière aéronautique	Exigence contractuelle	Applicabilité probable — à confirmer	Niveau AirCyber exigé contractuellement par des clients de l'organisation. L'organisation a déclaré cette exigence (identifiée).
EN 9100 — Management de la qualité (aéronautique, spatial, défense)	Norme volontaire	Applicabilité probable — à confirmer	Certification EN 9100 détenue ou exigée par les clients. L'organisation a déclaré cette exigence (identifiée).

État des normes ISO surveillées (métadonnées ISO Open Data)

Référence	Stade	Publication	Mise à jour
ISO 22301:2019	90.92 — Décision : à réviser	2019-10-30	2026-10-29
ISO 22301:2019/Amd 1:2024	60.60 — Norme publiée	2024-02-23	2026-10-29

Référence	Stade	Publication	Mise à jour
ISO/IEC 27001:2022	60.60 — Norme publiée	2022-10-25	2026-10-29
ISO/IEC 27001:2022/Amd 1:2024	60.60 — Norme publiée	2024-02-23	2026-10-29
ISO/IEC 27002:2022	60.60 — Norme publiée	2022-02-15	2026-10-29
ISO/IEC 27005:2022	60.60 — Norme publiée	2022-10-25	2026-10-29
ISO/IEC 27017:2026	60.60 — Norme publiée	2026-07-27	2026-10-29
ISO/IEC 27018:2025	60.60 — Norme publiée	2025-08-26	2026-10-29
ISO/IEC 27035-1:2023	60.60 — Norme publiée	2023-02-13	2026-10-29
ISO/IEC 27035-2:2023	60.60 — Norme publiée	2023-02-13	2026-10-29
ISO/IEC 27035-3:2020	90.60 — Examen systématique clos	2020-09-16	2026-10-29
ISO/IEC 27035-4:2024	60.60 — Norme publiée	2024-12-02	2026-10-29
ISO/IEC 27701:2025	60.60 — Norme publiée	2025-10-14	2026-10-29
ISO/IEC 42001:2023	60.60 — Norme publiée	2023-12-18	2026-10-29

Évolutions détectées sur la période

[À qualifier] Kicking off Cybersecurity Career Week with NIST!

https://www.nist.gov/blogs/cybersecurity-insights/kicking-cybersecurity-career-week-nist

Source : NIST — Cybersecurity Insights (blog) — publié le 2026-10-14, consulté le 2026-10-29

Catégorie : Bonne pratique ou recommandation, Évolution normative — mots-clés : awareness, how to, NIST Cybersecurity Framework 2.0

[Analyse] Résumé : Bonne pratique ou recommandation — publication de NIST — Cybersecurity Insights (blog) du 2026-10-14. Extrait original (en) : « Considering a career in cybersecurity? Cybersecurity Career Week (CCW), a campaign led by the NICE Program at NIST from October 19-24, 2026, aims to raise public awareness and help people find their path to #ChooseCyber. During this week, academia, industry, non-profit organizations, and government agencies host events, share resources, provide […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Référentiel de bonnes pratiques

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : a_qualifier — Applicabilité du texte à qualifier.

[Analyse] Priorité : À qualifier — Score 8 = 8 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : a_qualifier.

[Recommandation] : (1) Évaluer l'impact de l'évolution de « NIST Cybersecurity Framework 2.0 » (référentiel de bonnes pratiques) sur les pratiques de sécurité, les engagements contractuels et, le cas échéant, le SMSI. (2) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégrer les mesures pertinentes au plan d'amélioration. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Qualification requise (sous 7 jours)

Confiance de l'analyse : moyenne

[À qualifier] NIST Report Provides Guidelines for Transition to Post-Quantum Cryptography Standards

https://www.nist.gov/news-events/news/2026/10/nist-report-provides-guidelines-transition-post-quantum-cryptography

Source : NIST — Actualités (filtrées sécurité) — publié le 2026-10-27, consulté le 2026-10-29

Catégorie : Évolution technologique, Évolution normative — mots-clés : post-quantum, quantum, cryptograph, standard, NIST Cybersecurity Framework 2.0

[Analyse] Résumé : Évolution technologique — publication de NIST — Actualités (filtrées sécurité) du 2026-10-27. Thèmes : Cryptographie, post-quantique et gestion des secrets. Extrait original (en) : « This report describes the timelines and migration activities for federal agencies, and it can serve as a key resource for technology providers and organizations that are developing their quantum-readiness road maps. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Référentiel de bonnes pratiques

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : a_qualifier — Applicabilité du texte à qualifier.

[Analyse] Priorité : À qualifier — Score 8 = 8 (Importance réglementaire / normative) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : a_qualifier.

[Recommandation] : (1) Évaluer l'impact de l'évolution de « NIST Cybersecurity Framework 2.0 » (référentiel de bonnes pratiques) sur les pratiques de sécurité, les engagements contractuels et, le cas échéant, le SMSI. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2026-11-07 — urgence : Qualification requise (sous 7 jours)

Confiance de l'analyse : moyenne

[Faible] First harmonised standard supporting the AI Act published in the Official Journal

https://digital-strategy.ec.europa.eu/en/library/first-harmonised-standard-supporting-ai-act-published-official-journal

Source : Commission européenne — Stratégie numérique (filtrée) — publié le 2026-10-19, consulté le 2026-10-29

Catégorie : Évolution réglementaire, Évolution normative, Évolution technologique — mots-clés : Official Journal, AI Act, legal, ISO, IEC, standard, artificial intelligence, AI

[Analyse] Résumé : Évolution réglementaire — publication de Commission européenne — Stratégie numérique (filtrée) du 2026-10-19. Thèmes : Intelligence artificielle et IA générative. Extrait original (en) : « First harmonised standard supporting the AI Act published in the Official Journal Anonymous (not verified) Mon, 10/19/2026 - 09:37 The European Commission has published the reference to the first harmonised standard supporting the implementation of the AI Act in the Official Journal of the European Union. The standard, EN 18286:2026 - Artificial […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Obligation légale (texte contraignant)

Avertissement : Texte contraignant : vérifier le champ d'application.

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative.

[Analyse] Priorité : Faible — Score 18 = 8 (Importance réglementaire / normative) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Qualifier l'applicabilité de « AI Act — Règlement européen sur l'intelligence artificielle » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : moyenne

[À vérifier] : Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Faible] Localizing compliance at scale: achieving South Korea’s ISMS certification

https://blog.cloudflare.com/k-isms/

Source : Cloudflare Blog — publié le 2026-10-22, consulté le 2026-10-29

Catégorie : Évolution technologique, Évolution réglementaire, Évolution normative — mots-clés : cloud, compliance, certification, ISO/IEC 27001

[Analyse] Résumé : Évolution technologique — publication de Cloudflare Blog du 2026-10-22. Produits cités : Edge. Thèmes : Sécurité du cloud, des conteneurs et de la chaîne logicielle, Cryptographie, post-quantique et gestion des secrets. Extrait original (en) : « Cloudflare has achieved South Korea's ISMS certification following an audit across 80 controls. Learn how we localized user consent flows, adapted social sign-up paths at the edge, and validated our global security program. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Norme volontaire

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

Produits cités : Edge

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Thème surveillé : Sécurité du cloud, des conteneurs et de la chaîne logicielle.

[Analyse] Priorité : Faible — Score 18 = 8 (Importance réglementaire / normative) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Évaluer l'impact de l'évolution de « ISO/IEC 27001 — Systèmes de management de la sécurité de l'information » (norme volontaire) sur les pratiques de sécurité, les engagements contractuels et, le cas échéant, le SMSI. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité). Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Faible] NIK C2: The new AI-enabled command-and-control framework

https://blog.talosintelligence.com/nik-c2-new-ai-enabled-framework/

Source : Cisco Talos Intelligence — publié le 2026-10-29, consulté le 2026-10-29

Catégorie : Menace ou campagne d'attaque, Évolution technologique, Évolution normative — mots-clés : C2, AI, framework

[Analyse] Résumé : Menace ou campagne d'attaque — publication de Cisco Talos Intelligence du 2026-10-29. Produits cités : Cisco. Thèmes : Intelligence artificielle et IA générative. Extrait original (en) : « Cisco Talos observed a new AI-integrated command-and-control (C2) framework in the wild called “NIK C2.” » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Référentiel de bonnes pratiques

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

Produits cités : Cisco

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative.

[Analyse] Priorité : Faible — Score 18 = 10 (Thème surveillé) + 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : faible

[À vérifier] : Présence éventuelle dans le parc à confirmer : Cisco. Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Faible] AWS Continuum sets a new standard in autonomous code security

https://aws.amazon.com/blogs/security/aws-continuum-sets-a-new-standard-in-autonomous-code-security/

Source : AWS Security Blog — publié le 2026-10-05, consulté le 2026-10-29

Catégorie : Évolution technologique, Évolution normative — mots-clés : AI, standard

[Analyse] Résumé : Évolution technologique — publication de AWS Security Blog du 2026-10-05. Produits cités : Teams. Thèmes : Intelligence artificielle et IA générative, Sécurité du cloud, des conteneurs et de la chaîne logicielle. Extrait original (en) : « As AI models become more capable, they uncover more security vulnerabilities and identify increasingly sophisticated paths to exploit them, raising the bar for how quickly defenders must respond. Security teams now face more potential vulnerabilities than their existing processes were designed to handle — each requiring investigation, […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Recommandation (non contraignante)

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

Produits cités : Teams

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative, Sécurité du cloud, des conteneurs et de la chaîne logicielle.

[Analyse] Priorité : Faible — Score 10 = 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Faible] Introducing Privateer: AI-Assisted Security & Compliance Evaluation Framework Joins the OpenSSF Sandbox

https://openssf.org/blog/2026/10/13/introducing-privateer-ai-assisted-security-compliance-evaluation-framework-joins-the-openssf-sandbox/

Source : OpenSSF — Blog — publié le 2026-10-13, consulté le 2026-10-29

Catégorie : Évolution technologique, Évolution normative, Évolution réglementaire — mots-clés : AI, introducing, framework, compliance

[Analyse] Résumé : Évolution technologique — publication de OpenSSF — Blog du 2026-10-13. Thèmes : Intelligence artificielle et IA générative, Machine learning appliqué à la cybersécurité. Extrait original (en) : « Discover Privateer, a new plugin-based, AI-assisted security and compliance evaluation framework that has officially joined the OpenSSF Sandbox under the ORBIT Working Group. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Référentiel de bonnes pratiques

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative.

[Analyse] Priorité : Faible — Score 10 = 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Identifier le texte concerné et qualifier son applicabilité (secteur, taille, rôle de l'organisation). (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité). Statut juridique, dates et champ d'application à confirmer sur le texte officiel (EUR-Lex, Légifrance).

[Faible] Design Tenets for Agent Identity Management Systems

https://www.nist.gov/blogs/cybersecurity-insights/design-tenets-agent-identity-management-systems

Source : NIST — Cybersecurity Insights (blog) — publié le 2026-10-27, consulté le 2026-10-29

Catégorie : Évolution technologique, Évolution normative — mots-clés : agentic, authentication, identity, IAM, public comment

[Analyse] Résumé : Évolution technologique — publication de NIST — Cybersecurity Insights (blog) du 2026-10-27. Thèmes : Intelligence artificielle et IA générative, Zero Trust, IAM, MFA et gestion des identités. Extrait original (en) : « This is blog #2 in our series on agentic identity, authentication and authorization. Our other post can be found via Post #1. In our last blog post, we highlighted the essential nature of having fundamentally sound identity and access management (IAM) capabilities as a precursor to implementing agents at scale. We started to form the core of what […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Recommandation (non contraignante)

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative, Zero Trust, IAM, MFA et gestion des identités.

[Analyse] Priorité : Faible — Score 10 = 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : moyenne

[Faible] New LF Research Survey Shows Generative AI Cuts Open Source Coding Time in Half, but 25% of Incoming Pull Requests are Considered AI Slop

https://openssf.org/press-release/2026/10/30/new-lf-research-survey-shows-generative-ai-cuts-open-source-coding-time-in-half-but-25-of-incoming-pull-requests-are-considered-ai-slop/

Source : OpenSSF — Blog — publié le 2026-10-30, consulté le 2026-10-31

Catégorie : Évolution technologique, Évolution normative — mots-clés : AI, generative

[Analyse] Résumé : Évolution technologique — publication de OpenSSF — Blog du 2026-10-30. Produits cités : Linux. Thèmes : Intelligence artificielle et IA générative, DevSecOps, SBOM et sécurité des dépendances. Extrait original (en) : « While Generative AI boosts developer productivity and lowers barriers to entry, a new Linux Foundation Research report reveals it also increases maintainer workloads. With 25% of incoming pull requests now considered "AI slop," the findings highlight an urgent need for stronger open source project governance. » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Recommandation (non contraignante)

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

Produits cités : Linux

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Thème surveillé : Intelligence artificielle et IA générative.

[Analyse] Priorité : Faible — Score 10 = 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : faible

[À vérifier] : Source secondaire : recouper avec une source primaire (éditeur, CERT-FR, autorité).

[Faible] Securing Water and Wastewater Operational Technology Environments

https://www.nist.gov/blogs/cybersecurity-insights/securing-water-and-wastewater-operational-technology-environments

Source : NIST — Cybersecurity Insights (blog) — publié le 2026-10-01, consulté le 2026-10-29

Catégorie : Incident ou retour d'expérience, Évolution normative — mots-clés : incident, cyberattack

[Analyse] Résumé : Incident ou retour d'expérience — publication de NIST — Cybersecurity Insights (blog) du 2026-10-01. Extrait original (en) : « Recent cyberattacks on the U.S. water and wastewater systems (WWS) sector are highlighting the escalating threat to our nation’s critical infrastructure and the practical challenges of securing it. These incidents underscore an important challenge: the connectivity that utilities depend upon must be designed and operated with security as a core […] » (Synthèse automatique par règles, sans traduction : se référer à l'article original.)

[Analyse] Type de document : Recommandation (non contraignante)

Avertissement : Une norme, un référentiel ou une recommandation ne constitue pas une obligation légale, sauf si un texte, un contrat ou une certification visée la rend exigible.

Exploitation : Aucune information d'exploitation

[Analyse] Impact potentiel : Conformité

[Analyse] Pertinence : moyenne — Menace ou pratique générique, potentiellement transposable au SI de l'organisation.

[Analyse] Priorité : Faible — Score 8 = 8 (Menace transposable) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : moyenne.

[Recommandation] : (1) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Échéance proposée : 2027-01-29 — urgence : Faible (prochaine revue de veille)

Confiance de l'analyse : moyenne

11. Analyse des impacts pour l'organisation

Actifs du parc concernés

Technologie	Exposition	Criticité	Éléments	Priorité max.
Microsoft 365 (Exchange Online, Teams, SharePoint)	internet	elevee	4	Élevée
Pare-feu et VPN SSL (géré par l'infogérant)	internet	critique	3	Élevée
Intranet (nginx)	interne	faible	3	Élevée
Active Directory (corp.aerostar.lan)	interne	critique	2	Modérée
Microsoft Entra ID	internet	critique	1	Élevée
Serveur de fichiers du BE (partages SMB, ~8 To)	interne	critique	1	Modérée

[Analyse] Types d'impact potentiels (éléments de priorité modérée ou plus) : Intégrité (75), Disponibilité (53), Confidentialité (35), Conformité (16).

Lien avec les scénarios redoutés

Scénario	Éléments liés	dont prio. ≥ modérée	Priorité max.	Exemples
Rançongiciel via compte volé et compromission de l'AD	54	46	Élevée	Cisco Secure Firewall Adaptive Security Appliance and Secure Firewall Threat Defense Softw (Cisco — Security Advisories); New Cisco firewall zero-day exploited to crash SSL VPN devices (BleepingComputer); Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware (The Hacker News)
Compromission de messagerie Microsoft 365 par hameçonnage	12	5	Élevée	AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise (Microsoft Security Blog); Agents are your newest insiders. Security must move at their speed. (Microsoft Security Blog); ThreatsDay: Critical Firewall Flaws, Banking Trojans Rented, Weaponized PDF, Token Theft + (The Hacker News)
Fuite ou vol de plans et maquettes clients	9	5	Modérée	AlerteCyber : Failles de sécurité critiques dans PHP (Cybermalveillance.gouv.fr — Actualités); VAPOR PANDA Uses AI-Driven ARTEX to Scale a Global Espionage Campaign (CrowdStrike Blog); Evolution of Web3 in Cloud Supply Chain Attacks (Palo Alto Networks — Unit 42)

[Analyse] Ces éléments alimentent la mise à jour de l'analyse de risques : ils renseignent sur la vraisemblance des scénarios (modes opératoires actifs, vulnérabilités exploitées) et sur les mesures à renforcer.

Confrontation aux besoins de sécurité

Besoin	Exigence cible	Éléments menaçant ce critère (prio. ≥ modérée)
Protéger les plans et maquettes clients	Confidentialité : Très forte	35
Livrer à la date contractuelle (moins de 4 h d'arrêt du BE en journée)	Disponibilité : Forte	53
Garantir que le plan livré est le bon (gestion de configuration)	Intégrité : Très forte	75
Prouver qui a modifié quoi (EN 9100, audits clients)	Traçabilité : Forte	Non mesuré automatiquement (critère de traçabilité)

[Hypothèse] Les impacts sont des potentialités déduites du contenu des sources et du profil déclaré ; l'exposition réelle doit être confirmée par une vérification sur le SI (aucun scan n'est réalisé par l'outil).

12. Obligations potentielles à vérifier et échéances

Engagements propres à l'organisation

Engagement	Nature	Statut	Contenu
Contrats clients (NDA, plans d'assurance sécurité)	Exigence contractuelle	Identifiée	Confidentialité, audit, notification d'incident sous 24 h
AirCyber (BoostAeroSpace)	Exigence contractuelle	Identifiée	Bronze fin 2027, Silver ensuite
Assurance cyber	Exigence contractuelle	Identifiée	MFA généralisé et sauvegardes testées exigés au renouvellement 2027

Échéance	Objet	Origine	Délai restant
2027	Renouvellement de l'assurance cyber conditionné au MFA généralisé et à des sauvegardes testées	Assureur (septembre 2026)	courant 2027 (date exacte à préciser)
2027-12-31	Niveau AirCyber Bronze exigé par Nacelia Systems et Garonne Aérostructures (Silver ensuite)	Exigence contractuelle clients (juin 2026)	dans 426 jours (~14 mois)

[Fait] Engagements déclarés dans le profil de l'organisation (contrats, assureur) : ils s'imposent par contrat, pas par la loi.

Textes et référentiels

Texte	Applicabilité	Obligations possibles (à vérifier)	Échéances	Remarques / sources
RGPD	Applicabilité probable — à confirmer	Tenue du registre des traitements (art. 30); Sécurité des traitements adaptée au risque (art. 32); Notification des violations de données à la CNIL sous 72 h (art. 33) et aux personnes si risque élevé (art. 34); Analyse d'impact (AIPD) pour les traitements à risque élevé (art. 35)	En vigueur depuis 2018-05-25	Sources : https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679
NIS 2	Applicabilité à qualifier	Enregistrement auprès de l'autorité nationale (ANSSI); Mesures de gestion des risques cyber (art. 21) approuvées par les organes de direction (art. 20); Notification des incidents importants : alerte précoce 24 h, notification 72 h, rapport final 1 mois (art. 23); Sécurité de la chaîne d'approvisionnement	En vigueur depuis 2024-10-18	En France, la transposition passe par le projet de loi relatif à la résilience des infrastructures critiques et au renforcement de la cybersécurité, toujours en discussion au Parlement selon les informations disponibles en octobre 2026 ; point à suivre (flux du Sénat collectés), puis décrets d'application. Statut et dates nationales à vérifier sur Légifrance et sur le site de l'ANSSI. Sources : https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022L2555, https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32024R2690
AI Act	Applicabilité à qualifier	Recenser les systèmes d'IA utilisés ou développés et les classer par niveau de risque; Maîtrise de l'IA (formation) du personnel concerné (art. 4); Obligations des déployeurs de systèmes à haut risque (art. 26); Obligations de transparence (art. 50)	2027-08-02 : Systèmes à haut risque intégrés à des produits réglementés (annexe I)	Le calendrier d'application de certaines obligations (notamment haut risque) a fait l'objet de propositions de modification par la Commission (« omnibus numérique », 2025). Les dates ci-dessus sont celles du texte initial : le calendrier en vigueur doit être vérifié sur EUR-Lex. Sources : https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32024R1689, https://ai-act-service-desk.ec.europa.eu/
AirCyber	Applicabilité probable — à confirmer	Atteindre le niveau de maturité exigé contractuellement (évaluation par BoostAeroSpace); Maintenir le niveau et progresser vers le niveau supérieur selon le calendrier des clients	À vérifier	Sources : https://boostaerospace.com/aircyber/
Contrôle des exportations de biens à double usage	Applicabilité à qualifier	Classer les données techniques et identifier celles relevant de la liste des biens à double usage; Obtenir une licence avant tout transfert hors UE concerné (y compris accès à distance, stockage cloud hors UE)	En vigueur depuis 2021-09-09	Sources : https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32021R0821, https://www.entreprises.gouv.fr/
Part-IS	Impact indirect probable (clients, contrats)	Système de management de la sécurité de l'information et gestion des risques cyber; Signalement des incidents de sécurité de l'information	En vigueur depuis 2026-02-22	Dates rédigées à partir de la connaissance du texte, non vérifiées automatiquement (EUR-Lex inaccessible aux clients automatisés) ; à confirmer sur EUR-Lex. Sources : https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022R1645, https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32023R0203

[À vérifier] Ces obligations sont « possibles » : elles dépendent de la qualification juridique de l'organisation. Les dates proviennent des textes officiels référencés et doivent être revérifiées.

13. Opportunités d'amélioration

- **[Recommandation] Élevée :** AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise (Microsoft Security Blog) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Élevée :** Microsoft urges Entra ID admins to migrate users to passkeys (BleepingComputer) — Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** Managing identity source transition for AWS IAM Identity Center (AWS Security Blog) — Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** Chainalysis discloses data breach from "offensive agentic techniques" (BleepingComputer) — Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** De la protection des données à la création de valeur en finance : des autorités européennes publient une étude et des bonnes pratiques (CNIL — Actualités) — Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** Managing AI Token Consumption for Operational Resilience (CISA — Cybersecurity Advisories) — Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** ⚡ Weekly Recap: This2Shell, That2Shell, Everything's an RCE? Rogue AI, Supply Chain Chaos and More (The Hacker News) — Vérifier si Teams est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** VAPOR PANDA Uses AI-Driven ARTEX to Scale a Global Espionage Campaign (CrowdStrike Blog) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** Evolution of Web3 in Cloud Supply Chain Attacks (Palo Alto Networks — Unit 42) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** “Next Exploit Opportunities”: How a Threat Actor Used AI to Help Plan and Execute Multiple Types of Cybercrime Activities (Palo Alto Networks — Unit 42) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks (Microsoft Security Blog) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.
- **[Recommandation] Modérée :** AI-Generated Fake Login Pages Are Making Account Takeovers Easier (The Hacker News) — Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Bénéfice attendu : amélioration de la sécurité ou de l'efficacité ; risques et prérequis à évaluer.

14. Plan d'action priorisé

#	Priorité	Constat / action proposée	Responsable	Échéance	Effort	Statut
74	Élevée	Microsoft urges Entra ID admins to migrate users to passkeys → Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-07	Moyen	À étudier
156	Élevée	AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation enca	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-07	Moyen	À étudier
179	Élevée	USN-8955-1: nginx vulnerabilities → Vérifier la présence et les versions de Intranet (nginx) concernées par l'avis (inventaire, outil de gestion de parc). Puis : (2) Appliquer le correctif de l'éditeur selon la procédure de gestion des correctifs (test, puis déploiement prioritaire). (3) Maturité cyber déclarée faible : privilégier le	Équipe IT interne (4 personnes) — pilotage : Responsable IT (référent sécurité)	2026-11-07	Moyen	À étudier
240	Élevée	CVE-2026-70125 Microsoft Office Outlook Remote Code Execution Vulnerability → Vérifier la présence et les versions de Microsoft 365 (Exchange Online, Teams, SharePoint) concernées par l'avis (inventaire, outil de gestion de parc). Puis : (2) Service géré par le fournisseur (Microsoft 365 (Exchange Online, Teams, SharePoint)) : vérifier l'avis du fournisseur et les actions éve	Équipe IT interne (4 personnes) — pilotage : Responsable IT (référent sécurité)	2026-11-07	Moyen	À étudier
242	Élevée	nginx-1.30.6 stable and nginx-1.31.7 mainline versions have been released, with fixes for buffer overflow vulnerability when using alias wit → Vérifier la présence et les versions de Intranet (nginx) concernées par l'avis (inventaire, outil de gestion de parc). Puis : (2) Appliquer le correctif de l'éditeur selon la procédure de gestion des correctifs (test, puis déploiement prioritaire). (3) Maturité cyber déclarée faible : privilégier le	Équipe IT interne (4 personnes) — pilotage : Responsable IT (référent sécurité)	2026-11-07	Moyen	À étudier
256	Élevée	New Cisco firewall zero-day exploited to crash SSL VPN devices → Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire. Puis : (2) Vérifier la présence et les versions de Pare-feu et VPN SSL (géré par l'infogérant) c	Occitanie Numérique Services (infogérant) (exécution) — suivi : Responsable IT (référent sécurité)	2026-11-07	Moyen	À étudier
257	Élevée	Cisco Secure Firewall Adaptive Security Appliance and Secure Firewall Threat Defense Software Remote Access SSL VPN Tunnel Denial of Service → Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire. Puis : (2) Vérifier la présence et les versions de Pare-feu et VPN SSL (géré par l'infogérant) c	Occitanie Numérique Services (infogérant) (exécution) — suivi : Responsable IT (référent sécurité)	2026-11-07	Moyen	À étudier
259	Élevée	Agents are your newest insiders. Security must move at their speed. → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les proj	Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)	2026-11-07	Faible	À étudier

#	Priorité	Constat / action proposée	Responsable	Échéance	Effort	Statut
260	Élevée	Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Informer les utilisateurs du mode opératoire décrit (message de sensibilisation ciblé). (3) Vérifier l'existence de sauvegarde	Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)	2026-11-07	Faible	À étudier
3	À qualifier	Kicking off Cybersecurity Career Week with NIST! → Évaluer l'impact de l'évolution de « NIST Cybersecurity Framework 2.0 » (référentiel de bonnes pratiques) sur les pratiques de sécurité, les engagements contractuels et, le cas échéant, le SMSI. Puis : (2) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégrer les m	Responsable IT (référent sécurité) — pilotage : Équipe IT interne (4 personnes)	2026-11-07	Faible	À valider
252	À qualifier	NIST Report Provides Guidelines for Transition to Post-Quantum Cryptography Standards → Évaluer l'impact de l'évolution de « NIST Cybersecurity Framework 2.0 » (référentiel de bonnes pratiques) sur les pratiques de sécurité, les engagements contractuels et, le cas échéant, le SMSI. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs,	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-07	Moyen	À valider
23	Modérée	Journée RGPD à Poitiers : cybersécurité, IA et conformité au cœur des enjeux de protection des données → Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (corr	Direction, avec un juriste ou DPO externe — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
24	Modérée	De la protection des données à la création de valeur en finance : des autorités européennes publient une étude et des bonnes pratiques → Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Puis : (2) Comparer les recommandations avec la configuration et les pratiques actuelles ; intégr	Direction, avec un juriste ou DPO externe — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
25	Modérée	Reconstitution d’adresses électroniques professionnelles : dans quel cadre est-ce autorisé ? → Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (corr	Direction, avec un juriste ou DPO externe — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
26	Modérée	Reconstitution d’adresses électroniques professionnelles : quels sont vos droits ? → Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (corr	Direction, avec un juriste ou DPO externe — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
27	Modérée	Clôture de l’injonction prononcée à l’encontre de GOOGLE → Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (corr	Direction, avec un juriste ou DPO externe — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
28	Modérée	Le CEPD publie une déclaration sur les enjeux de protection des données liés aux lunettes connectées → Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (corr	Direction, avec un juriste ou DPO externe — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier

#	Priorité	Constat / action proposée	Responsable	Échéance	Effort	Statut
41	Modérée	EDPB publishes statement on the data protection challenges of smart glasses → Qualifier l'applicabilité de « RGPD — Règlement général sur la protection des données » avec le juriste/DPO puis, si applicable, réaliser une analyse d'écarts et mettre à jour le registre des exigences. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (corr	Direction, avec un juriste ou DPO externe — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
105	Modérée	Managing AI Token Consumption for Operational Resilience → Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : pri	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
183	Modérée	Managing identity source transition for AWS IAM Identity Center → Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
238	Modérée	Chainalysis discloses data breach from "offensive agentic techniques" → Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : pri	Responsable IT (référent sécurité)	2026-11-30	Faible	À étudier
239	Modérée	Appraisal by AI: Model-driven victim prioritization in the VOLTA infostealer → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). (3) Étude	Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)	2026-11-30	Faible	À étudier
241	Modérée	In Other News: Anthropic Breach Dispute, UEFI Flaw Hits Most Servers, Cloudflare AI Data Leak → Analyser le retour d'expérience et vérifier si le scénario est transposable (fournisseurs, technologies, processus). Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : pri	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
243	Modérée	VAPOR PANDA Uses AI-Driven ARTEX to Scale a Global Espionage Campaign → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation enca	Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)	2026-11-30	Faible	À étudier
245	Modérée	Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation enca	Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)	2026-11-30	Faible	À étudier
246	Modérée	“Next Exploit Opportunities”: How a Threat Actor Used AI to Help Plan and Execute Multiple Types of Cybercrime Activities → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation enca	Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)	2026-11-30	Faible	À étudier

#	Priorité	Constat / action proposée	Responsable	Échéance	Effort	Statut
247	Modérée	Evolution of Web3 in Cloud Supply Chain Attacks → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation enca	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
248	Modérée	American Organizations Under Attack: Skyw4lker Device Code Phishing Campaign Exposed → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Informer les utilisateurs du mode opératoire décrit (message de sensibilisation ciblé). (3) Analyser le retour d'expérience et	Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)	2026-11-30	Faible	À étudier
249	Modérée	AI-Generated Fake Login Pages Are Making Account Takeovers Easier → Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Informer les utilisateurs du mode opératoire décrit (message de sensibilisation ciblé). (3) Étude d'opportunité : évaluer béné	Direction générale — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier
261	Modérée	⚡ Weekly Recap: This2Shell, That2Shell, Everything's an RCE? Rogue AI, Supply Chain Chaos and More → Vérifier si Teams est utilisé dans le SI (inventaire potentiellement incomplet) ; sinon, classer l'information comme non applicable. Puis : (2) Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de superv	Équipe IT interne (4 personnes) — pilotage : Responsable IT (référent sécurité)	2026-11-30	Moyen	À étudier

Détail des actions critiques et élevées

Action n° 74 — Élevée

https://www.bleepingcomputer.com/news/microsoft/microsoft-reminds-entra-id-admins-to-migrate-users-to-passkeys/

Constat : Microsoft urges Entra ID admins to migrate users to passkeys — BleepingComputer (2026-10-28). https://www.bleepingcomputer.com/news/microsoft/microsoft-reminds-entra-id-admins-to-migrate-users-to-passkeys/

Risque / opportunité : Opportunité d'amélioration : Zero Trust, IAM, MFA et gestion des identités, Sécurité de la messagerie et lutte contre l'hameçonnage. Risques associés à évaluer avant adoption.

[Recommandation] Action : Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Justification : Score 60 = 25 (Présence dans le parc) + 15 (Exposition) + 10 (Impact sur les activités) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Direction générale — pilotage : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Moyen

Bénéfice attendu : Gain de sécurité ou d'efficacité, décision d'adoption argumentée.

Coût estimé : À chiffrer

Preuves de réalisation : Note d'opportunité (bénéfices, risques, prérequis), décision de la direction.

Statut : À étudier

Action n° 156 — Élevée

https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

Constat : AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise — Microsoft Security Blog (2026-10-21). https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/

Risque / opportunité : Opportunité d'amélioration : Intelligence artificielle et IA générative, Machine learning appliqué à la cybersécurité, Sécurité du cloud, des conteneurs et de la chaîne logicielle. Risques associés à évaluer avant adoption.

[Recommandation] Action : Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Étude d'opportunité : évaluer bénéfices, risques et prérequis de sécurité pour l'organisation avant toute expérimentation encadrée. (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (4) Mettre à jour l'analyse du scénario redouté « Compromission de messagerie Microsoft 365 par hameçonnage » (vraisemblance, mesures existantes) au vu de cette information.

Justification : Score 66 = 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) + 10 (Scénario redouté) + 10 (Thème surveillé) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Direction générale — pilotage : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Moyen

Bénéfice attendu : Gain de sécurité ou d'efficacité, décision d'adoption argumentée.

Coût estimé : À chiffrer

Preuves de réalisation : Note d'opportunité (bénéfices, risques, prérequis), décision de la direction.

Statut : À étudier

Action n° 179 — Élevée

https://ubuntu.com/security/notices/USN-8955-1

Constat : USN-8955-1: nginx vulnerabilities — Ubuntu — Security Notices (2026-10-26). https://ubuntu.com/security/notices/USN-8955-1

Risque / opportunité : Risque : compromission de Intranet (nginx) (atteinte à : intégrité, disponibilité).

[Recommandation] Action : Vérifier la présence et les versions de Intranet (nginx) concernées par l'avis (inventaire, outil de gestion de parc). Puis : (2) Appliquer le correctif de l'éditeur selon la procédure de gestion des correctifs (test, puis déploiement prioritaire). (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Justification : Score 55 = 30 (Gravité technique) + 25 (Présence dans le parc) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Équipe IT interne (4 personnes) — pilotage : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Moyen

Bénéfice attendu : Réduction de la surface d'attaque et du risque de compromission des actifs concernés.

Coût estimé : À chiffrer

Preuves de réalisation : Inventaire des versions avant/après, ticket de changement, rapport de déploiement du correctif, résultat de recherche de compromission.

Statut : À étudier

Action n° 240 — Élevée

https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70125

Constat : CVE-2026-70125 Microsoft Office Outlook Remote Code Execution Vulnerability — Microsoft — Security Update Guide (2026-10-30). https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70125

Risque / opportunité : Risque : compromission de Microsoft 365 (Exchange Online, Teams, SharePoint) (atteinte à : intégrité).

[Recommandation] Action : Vérifier la présence et les versions de Microsoft 365 (Exchange Online, Teams, SharePoint) concernées par l'avis (inventaire, outil de gestion de parc). Puis : (2) Service géré par le fournisseur (Microsoft 365 (Exchange Online, Teams, SharePoint)) : vérifier l'avis du fournisseur et les actions éventuellement requises côté client (configuration, MFA, journaux) — responsabilité partagée. (3) En attendant le correctif, réduire l'exposition (filtrage des accès, désactivation de la fonctionnalité vulnérable) selon les recommandations de l'éditeur. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Justification : Score 66 = 20 (Gravité technique) + 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Équipe IT interne (4 personnes) — pilotage : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Moyen

Bénéfice attendu : Réduction de la surface d'attaque et du risque de compromission des actifs concernés.

Coût estimé : À chiffrer

Preuves de réalisation : Inventaire des versions avant/après, ticket de changement, rapport de déploiement du correctif, résultat de recherche de compromission.

Statut : À étudier

Action n° 242 — Élevée

http://nginx.org/#2026-10-14

Constat : nginx-1.30.6 stable and nginx-1.31.7 mainline versions have been released, with fixes for buffer overflow vulnerability when using alias with rewrite (CVE-2026-15176), buffer overflow vulnerability when evaluating string expressions with variables (CVE-2026-93479), request body injection vulnerability in HTTP/3 (CVE-2026-95101), session forgery vulnerability when using TLS session ticket key [...] — nginx — Actualités (correctifs de sécurité) (2026-10-13). http://nginx.org/#2026-10-14

Risque / opportunité : Risque : compromission de Intranet (nginx) (atteinte à : intégrité).

[Recommandation] Action : Vérifier la présence et les versions de Intranet (nginx) concernées par l'avis (inventaire, outil de gestion de parc). Puis : (2) Appliquer le correctif de l'éditeur selon la procédure de gestion des correctifs (test, puis déploiement prioritaire). (3) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants.

Justification : Score 55 = 30 (Gravité technique) + 25 (Présence dans le parc) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Équipe IT interne (4 personnes) — pilotage : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Moyen

Bénéfice attendu : Réduction de la surface d'attaque et du risque de compromission des actifs concernés.

Coût estimé : À chiffrer

Preuves de réalisation : Inventaire des versions avant/après, ticket de changement, rapport de déploiement du correctif, résultat de recherche de compromission.

Statut : À étudier

Action n° 256 — Élevée

https://www.bleepingcomputer.com/news/security/cisco-warns-of-firewall-zero-day-exploited-to-crash-ssl-vpn-devices/

Constat : New Cisco firewall zero-day exploited to crash SSL VPN devices — BleepingComputer (2026-10-29). https://www.bleepingcomputer.com/news/security/cisco-warns-of-firewall-zero-day-exploited-to-crash-ssl-vpn-devices/

Risque / opportunité : Risque : compromission de Pare-feu et VPN SSL (géré par l'infogérant) (atteinte à : disponibilité).

[Recommandation] Action : Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire. Puis : (2) Vérifier la présence et les versions de Pare-feu et VPN SSL (géré par l'infogérant) concernées par l'avis (inventaire, outil de gestion de parc). (3) Demander à l'infogérant l'application du correctif sur Pare-feu et VPN SSL (géré par l'infogérant) et une confirmation écrite (modèle, version, date), à conserver comme preuve. (4) En attendant le correctif, réduire l'exposition (filtrage des accès, désactivation de la fonctionnalité vulnérable) selon les recommandations de l'éditeur. (5) Rechercher des traces d'exploitation dans les journaux disponibles (serveurs concernés, contrôleurs de domaine, pare-feu, SIEM/EDR s'il existe) depuis la date de divulgation, à l'aide des indicateurs publiés. (6) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (7) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Justification : Score 63 = 18 (Exploitation active) + 10 (Présence dans le parc) + 15 (Exposition) + 10 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Occitanie Numérique Services (infogérant) (exécution) — suivi : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Moyen

Bénéfice attendu : Réduction de la surface d'attaque et du risque de compromission des actifs concernés.

Coût estimé : À chiffrer

Preuves de réalisation : Inventaire des versions avant/après, ticket de changement, rapport de déploiement du correctif, résultat de recherche de compromission.

Statut : À étudier

Action n° 257 — Élevée

https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-tunnel-dos-s6mgkb75?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Secure%20Firewall%20Adaptive%20Security%20Appliance%20and%20Secure%20Firewall%20Threat%20Defense%20Software%20Remote%20Access%20SSL%20VPN%20Tunnel%20Denial%20of%20Service%20Vulnerability%26vs_k=1

Constat : Cisco Secure Firewall Adaptive Security Appliance and Secure Firewall Threat Defense Software Remote Access SSL VPN Tunnel Denial of Service Vulnerability — Cisco — Security Advisories (2026-10-28). https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-tunnel-dos-s6mgkb75?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Secure%20Firewall%20Adaptive%20Security%20Appliance%20and%20Secure%20Firewall%20Threat%20Defense%20Software%20Remote%20Access%20SSL%20VPN%20Tunnel%20Denial%20of%20Service%20Vulnerability%26vs_k=1

Risque / opportunité : Risque : compromission de Pare-feu et VPN SSL (géré par l'infogérant) (atteinte à : disponibilité).

[Recommandation] Action : Identifier la marque, le modèle et la version de « Pare-feu et VPN SSL (géré par l'infogérant) » (non documentés) auprès du gestionnaire pour déterminer si l'avis s'applique, puis compléter l'inventaire. Puis : (2) Vérifier la présence et les versions de Pare-feu et VPN SSL (géré par l'infogérant) concernées par l'avis (inventaire, outil de gestion de parc). (3) Demander à l'infogérant l'application du correctif sur Pare-feu et VPN SSL (géré par l'infogérant) et une confirmation écrite (modèle, version, date), à conserver comme preuve. (4) En attendant le correctif, réduire l'exposition (filtrage des accès, désactivation de la fonctionnalité vulnérable) selon les recommandations de l'éditeur. (5) Rechercher des traces d'exploitation dans les journaux disponibles (serveurs concernés, contrôleurs de domaine, pare-feu, SIEM/EDR s'il existe) depuis la date de divulgation, à l'aide des indicateurs publiés. (6) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (7) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Justification : Score 75 = 30 (Exploitation active) + 10 (Présence dans le parc) + 15 (Exposition) + 10 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte. Plafonné à « Élevée » : le niveau « Critique » exige une technologie du parc identifiée (marque connue) ET une gravité ou une exploitation vérifiée (KEV, CVSS ≥ 9, alerte CERT-FR).

Responsable suggéré : Occitanie Numérique Services (infogérant) (exécution) — suivi : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Moyen

Bénéfice attendu : Réduction de la surface d'attaque et du risque de compromission des actifs concernés.

Coût estimé : À chiffrer

Preuves de réalisation : Inventaire des versions avant/après, ticket de changement, rapport de déploiement du correctif, résultat de recherche de compromission.

Statut : À étudier

Action n° 259 — Élevée

https://www.microsoft.com/en-us/security/blog/2026/10/19/agents-are-your-newest-insiders-security-must-move-at-their-speed/

Constat : Agents are your newest insiders. Security must move at their speed. — Microsoft Security Blog (2026-10-19). https://www.microsoft.com/en-us/security/blog/2026/10/19/agents-are-your-newest-insiders-security-must-move-at-their-speed/

Risque / opportunité : Risque : exposition au mode opératoire décrit (atteinte à : impact à qualifier).

[Recommandation] Action : Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (3) Mettre à jour l'analyse du scénario redouté « Compromission de messagerie Microsoft 365 par hameçonnage » (vraisemblance, mesures existantes) au vu de cette information.

Justification : Score 56 = 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Faible

Bénéfice attendu : Meilleure capacité de prévention et de détection face à une menace active.

Coût estimé : À chiffrer

Preuves de réalisation : Règles de détection créées ou vérifiées, compte rendu de test de détection, message de sensibilisation diffusé.

Statut : À étudier

Action n° 260 — Élevée

https://thehackernews.com/2026/10/attackers-use-microsoft-teams-it.html

Constat : Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware — The Hacker News (2026-10-26). https://thehackernews.com/2026/10/attackers-use-microsoft-teams-it.html

Risque / opportunité : Risque : exposition au mode opératoire décrit (atteinte à : intégrité, disponibilité).

[Recommandation] Action : Vérifier la capacité à détecter les techniques et indicateurs décrits (antivirus/EDR, journaux, SIEM s'il existe) ; à défaut, l'intégrer au projet de supervision. Puis : (2) Informer les utilisateurs du mode opératoire décrit (message de sensibilisation ciblé). (3) Vérifier l'existence de sauvegardes hors ligne et tester une restauration. (4) Maturité cyber déclarée faible : privilégier les mesures simples et à fort effet (correctifs, MFA, sauvegardes) avant les projets structurants. (5) Mettre à jour l'analyse du scénario redouté « Rançongiciel via compte volé et compromission de l'AD » (vraisemblance, mesures existantes) au vu de cette information.

Justification : Score 56 = 25 (Présence dans le parc) + 15 (Exposition) + 6 (Impact sur les activités) + 10 (Scénario redouté) Seuils : Critique ≥ 75 (avec conditions), Élevée ≥ 50, Modérée ≥ 25. Pertinence : forte.

Responsable suggéré : Responsable IT (aucune supervision centralisée à ce jour) — pilotage : Responsable IT (référent sécurité)

Échéance indicative : 2026-11-07

Effort estimé : Faible

Bénéfice attendu : Meilleure capacité de prévention et de détection face à une menace active.

Coût estimé : À chiffrer

Preuves de réalisation : Règles de détection créées ou vérifiées, compte rendu de test de détection, message de sensibilisation diffusé.

Statut : À étudier

15. Limites de la veille et informations restant à confirmer

- **Source non collectée :** ANSSI — Guides et publications (cyber.gouv.fr) — Bloquée / non collectable : Alternative : Le site cyber.gouv.fr est protégé par un dispositif anti-robot (Incapsula) et ne fournit pas de flux RSS exploitable : aucune collecte automatique n'est tentée. Alternatives : les flux CERT-FR (même organisme) sont collectés automatiquement ; consultation manuelle mensuelle de la page des publications et saisie des nouveautés dans l'outil.
- **Source non collectée :** Légifrance — Journal officiel (JORF) — Bloquée / non collectable : Alternative : Les flux RSS publics de Légifrance renvoient une page de vérification anti-robot (HTTP 403, Cloudflare) : aucune collecte automatique n'est tentée. Alternatives : (1) API Légifrance officielle via le portail PISTE (compte et identifiants OAuth requis, piste.gouv.fr) ; (2) consultation manuelle hebdomadaire et saisie dans l'outil ; (3) suivi des textes européens via EUR-Lex.
- **Source non collectée :** Dassault Systèmes — Avis de sécurité (Trust Center) — Bloquée / non collectable : Alternative : Pas de flux RSS publié (page HTML uniquement, vérifié le 31/10/2026). Les CVE Dassault Systèmes remontent par le NVD, le catalogue CISA KEV et les avis CERT-FR, collectés automatiquement ; consultation manuelle mensuelle de la page.

- **CVSS :** 456 mentions de CVE sans score CVSS disponible (non estimé ; limite de débit du NVD ou CVE non encore évaluée).
- **Exploitation :** 18 éléments signalent une exploitation active non confirmée par le catalogue KEV.
- **Résumés :** 614 résumés sont des synthèses automatiques par règles de sources en langue étrangère (sans traduction) : consulter l'article original.
- **Classification :** Par règles et mots-clés : des faux positifs ou négatifs sont possibles ; l'analyste peut requalifier chaque élément (statut).
- **Inventaire :** La pertinence dépend de l'exhaustivité de l'inventaire déclaré ; les versions affectées ne sont pas comparées automatiquement.
- **Réglementaire :** L'applicabilité est une orientation ; les textes français (Légifrance) ne sont pas collectés automatiquement ; statut de transposition NIS 2 à vérifier.
- **Normes :** Les textes des normes ISO ne sont ni consultés ni reproduits (accès payant) : seules les métadonnées publiques sont suivies.
- **Fraîcheur :** 395 éléments anciens republiés dans les flux ont été exclus des résultats.
- **[Hypothèse] :** Organisation FICTIVE (cas d'étude) : les éléments de veille sont réellement collectés, mais le contexte, l'inventaire et les chiffres de l'organisation sont inventés.
- **[Hypothèse] :** Marque ou modèle non précisé pour : Pare-feu et VPN SSL (géré par l'infogérant), NAS de sauvegarde (salle serveur). La détection repose sur des mots-clés génériques : toute vulnérabilité d'un produit de ce type est à vérifier auprès du gestionnaire.
- **[Hypothèse] :** Versions non renseignées pour certaines technologies : la correspondance porte sur le produit, pas sur la version affectée (vérification manuelle nécessaire).

16. Conclusion

[Analyse] La veille de la période a permis d'identifier 9 éléments de priorité critique ou élevée, 38 évolutions réglementaires et 17 évolutions normatives, ainsi que 126 évolutions technologiques pertinentes. 30 actions sont proposées ; les actions critiques doivent être validées et lancées sans délai, les autres intégrées au plan de traitement des risques. La prochaine itération devra confirmer les points « à vérifier » listés ci-dessus et mettre à jour le profil de l'organisation si nécessaire.

17. Annexes — références consultées

Toutes les informations citées proviennent des URL ci-dessous ; la date de consultation correspond à la date de collecte automatique. 556 éléments de priorité faible non cités sont consultables dans l'outil.

#	Titre	Source	Publication	Consultation	URL
1	Cisco Secure Firewall Adaptive Security Appliance and Secure Firewall Threat Defense Software Remote Access SSL VPN Tunn	Cisco — Security Advisories	2026-10-28	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-tunnel-dos-s6mgkb75?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Secure%20Firewall%20Adaptive%20Security%20Appliance%20and%20Secure%20Firewall%20Threat%20Defense%20Software%20Remote%20Access%20SSL%20VPN%20Tunnel%20Denial%20of%20Service%20Vulnerability%26vs_k=1
2	AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise	Microsoft Security Blog	2026-10-21	2026-10-29	https://www.microsoft.com/en-us/security/blog/2026/10/21/storm-0940-uses-artex-agentic-ai-connectwise-supply-chain-compromise/
3	CVE-2026-70125 Microsoft Office Outlook Remote Code Execution Vulnerability	Microsoft — Security Update Guide	2026-10-30	2026-10-31	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-70125
4	New Cisco firewall zero-day exploited to crash SSL VPN devices	BleepingComputer	2026-10-29	2026-10-29	https://www.bleepingcomputer.com/news/security/cisco-warns-of-firewall-zero-day-exploited-to-crash-ssl-vpn-devices/
5	Microsoft urges Entra ID admins to migrate users to passkeys	BleepingComputer	2026-10-28	2026-10-29	https://www.bleepingcomputer.com/news/microsoft/microsoft-reminds-entra-id-admins-to-migrate-users-to-passkeys/
6	Agents are your newest insiders. Security must move at their speed.	Microsoft Security Blog	2026-10-19	2026-10-29	https://www.microsoft.com/en-us/security/blog/2026/10/19/agents-are-your-newest-insiders-security-must-move-at-their-speed/
7	Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware	The Hacker News	2026-10-26	2026-10-29	https://thehackernews.com/2026/10/attackers-use-microsoft-teams-it.html
8	nginx-1.30.6 stable and nginx-1.31.7 mainline versions have been released, with fixes for buffer overflow vulnerability	nginx — Actualités (correctifs de sécurité)	2026-10-13	2026-10-31	http://nginx.org/#2026-10-14
9	USN-8955-1: nginx vulnerabilities	Ubuntu — Security Notices	2026-10-26	2026-10-29	https://ubuntu.com/security/notices/USN-8955-1
10	Kicking off Cybersecurity Career Week with NIST!	NIST — Cybersecurity Insights (blog)	2026-10-14	2026-10-29	https://www.nist.gov/blogs/cybersecurity-insights/kicking-cybersecurity-career-week-nist
11	Compromised TLS Certificates	Schneier on Security	2026-10-23	2026-10-29	https://www.schneier.com/blog/archives/2026/10/compromised-tls-certificates.html
12	NIST Report Provides Guidelines for Transition to Post-Quantum Cryptography Standards	NIST — Actualités (filtrées sécurité)	2026-10-27	2026-10-29	https://www.nist.gov/news-events/news/2026/10/nist-report-provides-guidelines-transition-post-quantum-cryptography
13	[KEV] CVE-2015-3306 — ProFTPD ProFTPD : ProFTPD Improper Access Control Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-08	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2015-3306
14	[KEV] CVE-2026-111497 — Google Brotli : Google Brotli Unchecked Return Value Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-27	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-111497
15	[KEV] CVE-2021-3199 — ONLYOFFICE Docs : ONLYOFFICE Docs Server Path Traversal Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-08	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2021-3199

#	Titre	Source	Publication	Consultation	URL
16	[KEV] CVE-2026-97229 — GitLab Community Edition and Enterprise Edition : GitLab Community Edition and Enterprise Edition	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-29	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-97229
17	[KEV] CVE-2023-22894 — Strapi Strapi : Strapi Cleartext Storage of Sensitive Information Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-08	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2023-22894
18	[KEV] CVE-2016-3081 — Apache Struts : Apache Struts Command Injection Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-08	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2016-3081
19	[KEV] CVE-2015-5477 — ISC BIND : ISC BIND Data Processing Errors Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-08	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2015-5477
20	[KEV] CVE-2026-104935 — Ivanti Connect Secure : Ivanti Connect Secure Authentication Bypass by Spoofing Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-13	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-104935
21	Vulnérabilité dans Ivanti Connect Secure (ICS) (14 octobre 2026)	CERT-FR — Alertes de sécurité	2026-10-14	2026-10-29	https://www.cert.cyber.gouv.fr/alerte/CERTFR-2026-ALE-013/
22	Unit 42 Uncovers PEERSTITCH, a Stealthy FortiGate Implant	Palo Alto Networks — Unit 42	2026-10-14	2026-10-29	https://unit42.paloaltonetworks.com/fortimanager-cve-2024-47575-peerstitch-malware/
23	Node2Shell CVEs	Fortinet — PSIRT Advisories	2026-10-26	2026-10-29	https://fortiguard.fortinet.com/psirt/FG-IR-26-187
24	PHP Issues Second Windows Security Update in Five Days to Fix Brotli Code Execution Flaw	The Hacker News	2026-10-26	2026-10-29	https://thehackernews.com/2026/10/php-issues-second-windows-security.html
25	CISA Adds Two Known Exploited Vulnerabilities to Catalog	CISA — Cybersecurity Advisories	2026-10-27	2026-10-29	https://www.cisa.gov/news-events/alerts/2026/10/27/cisa-adds-two-known-exploited-vulnerabilities-catalog
26	Adobe Commerce PolyShell Attacks Breach Hundreds of Stores as Brotli Exploit Traffic Emerges	The Hacker News	2026-10-28	2026-10-29	https://thehackernews.com/2026/10/adobe-commerce-polyshell-attacks-breach.html
27	USN-8958-1: .NET vulnerabilities	Ubuntu — Security Notices	2026-10-29	2026-10-31	https://ubuntu.com/security/notices/USN-8958-1
28	Vulnerabilities in Node.js Affecting Cisco Products: October 2026	Cisco — Security Advisories	2026-10-29	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-oct2026-node-js-Jj3SQ19u?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Vulnerabilities%20in%20Node.js%20Affecting%20Cisco%20Products:%20October%202026%26vs_k=1
29	Attacker Tried to Exploit Alpine Linux’s GitLab via CVSS 10.0 Flaw Its Ruby Left Open	The Hacker News	2026-10-29	2026-10-29	https://thehackernews.com/2026/10/attacker-tried-to-exploit-alpine-linuxs.html
30	CISA Adds Two Known Exploited Vulnerabilities to Catalog	CISA — Cybersecurity Advisories	2026-10-29	2026-10-29	https://www.cisa.gov/news-events/alerts/2026/10/29/cisa-adds-two-known-exploited-vulnerabilities-catalog
31	CISA Adds Actively Exploited GitLab RCE and Cisco Firewall DoS Flaws to KEV	The Hacker News	2026-10-30	2026-10-31	https://thehackernews.com/2026/10/cisa-adds-actively-exploited-gitlab-rce.html
32	Max-Severity GitLab Vulnerability Exploited Against Alpine Linux	SecurityWeek	2026-10-30	2026-10-31	https://www.securityweek.com/max-severity-gitlab-vulnerability-exploited-against-alpine-linux/
33	php2shell: Assessing Elastic detection coverage relevant to CVE-2026-109618 and CVE-2026-109619	Elastic Security Labs	2026-10-21	2026-10-29	https://www.elastic.co/security-labs/threat-command/php2shell-php-rce-detection

#	Titre	Source	Publication	Consultation	URL
34	Mitsubishi Electric and Mitsubishi Electric Iconics Digital Solutions GENESIS, GENESIS64, ICONICS Suite, Hyper Historian	CISA — Cybersecurity Advisories	2026-10-27	2026-10-29	https://www.cisa.gov/news-events/ics-advisories/icsa-26-300-02
35	[KEV] CVE-2026-111357 — Ivanti Connect Secure : Ivanti Connect Secure Missing Authentication for Critical Function Vulne	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-30	2026-10-31	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-111357
36	[KEV] CVE-2026-118527 — Ivanti Connect Secure : Ivanti Connect Secure Generation of Predictable Numbers or Identifiers V	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-30	2026-10-31	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-118527
37	ShinyHunters-Exploited Oracle PeopleSoft Zero-Day Turns Out to Be Three Chained Flaws	The Hacker News	2026-10-28	2026-10-29	https://thehackernews.com/2026/10/shinyhunters-exploited-oracle.html
38	Active Exploitation of May 2026 PAN-OS CVE-2026-0257 (Updated October 20)	Palo Alto Networks — Unit 42	2026-10-20	2026-10-29	https://unit42.paloaltonetworks.com/active-exploitation-of-pan-os-cve-2026-0257/
39	Critical RCE vulnerabilities in PHP (CVE-2026-109618, CVE-2026-109619)	Securelist (Kaspersky GReAT)	2026-10-21	2026-10-29	https://securelist.com/tr/php2shell-critical-vulnerabilities-in-php/121596/
40	CISA Adds Two Known Exploited Vulnerabilities to Catalog	CISA — Cybersecurity Advisories	2026-10-26	2026-10-29	https://www.cisa.gov/news-events/alerts/2026/10/26/cisa-adds-two-known-exploited-vulnerabilities-catalog
41	Vulnerabilities in PHP Affecting Cisco Products: October 2026	Cisco — Security Advisories	2026-10-28	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-php-october26-Jj384Daq?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Vulnerabilities%20in%20PHP%20Affecting%20Cisco%20Products:%20October%202026%26vs_k=1
42	Cisco Catalyst SD-WAN Controller Authentication Bypass Vulnerability	Cisco — Security Advisories	2026-10-28	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-sdwan-rpa-EHchtZk?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Catalyst%20SD-WAN%20Controller%20Authentication%20Bypass%20Vulnerability%26vs_k=1
43	Threat Brief: Critical Vulnerabilities in PHP: CVE-2026-109618, CVE-2026-109619 (Updated October 29)	Palo Alto Networks — Unit 42	2026-10-29	2026-10-29	https://unit42.paloaltonetworks.com/cve-2026-109618-cve-2026-109619/
44	[KEV] CVE-2026-105133 — Ahsay AhsayCBS : Ahsay AhsayCBS Improper Authentication Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-14	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-105133
45	[KEV] CVE-2026-105134 — Ahsay AhsayCBS : Ahsay AhsayCBS Command Injection Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-14	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-105134
46	[KEV] CVE-2026-21589 — Atlassian Multiple Products : Atlassian Multiple Products Files or Directories Accessible to Exte	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-15	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-21589
47	Amazon Threat Intelligence identifies PHP2Shell exploitation prior to public disclosure in MadPot	AWS Security Blog	2026-10-21	2026-10-29	https://aws.amazon.com/blogs/security/amazon-threat-intelligence-identifies-php2shell-exploitation-prior-to-public-disclosure-in-madpot/
48	[KEV] CVE-2026-110447 — Collabora Collabora Online – Built-in CODE Server : Collabora Online – Built-in CODE Server OS C	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-23	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-110447

#	Titre	Source	Publication	Consultation	URL
49	[KEV] CVE-2026-109619 — PHP Group PHP : PHP Stale Internal Request-State Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-26	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-109619
50	[KEV] CVE-2026-109618 — PHP Group PHP : PHP Memory Corruption Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-26	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-109618
51	[KEV] CVE-2026-46300 — Linux Kernel : Linux Kernel Missing Initialization of a Variable Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-28	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-46300
52	CISA Adds Two Known Exploited Vulnerabilities to Catalog	CISA — Cybersecurity Advisories	2026-10-30	2026-10-31	https://www.cisa.gov/news-events/alerts/2026/10/30/cisa-adds-two-known-exploited-vulnerabilities-catalog
53	Attackers Chain Three Ivanti Connect Secure Flaws to Gain Unauthenticated Root Access	The Hacker News	2026-10-31	2026-10-31	https://thehackernews.com/2026/10/attackers-chain-three-ivanti-connect.html
54	Cisco Catalyst SD-WAN Manager API Authentication Bypass Vulnerability	Cisco — Security Advisories	2026-10-02	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-sdwan-webauth-xr8beuuU?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Catalyst%20SD-WAN%20Manager%20API%20Authentication%20Bypass%20Vulnerability%26vs_k=1
55	Multiples vulnérabilités dans Citrix NetScaler ADC et Gateway (28 septembre 2026)	CERT-FR — Alertes de sécurité	2026-09-28	2026-10-29	https://www.cert.cyber.gouv.fr/alerte/CERTFR-2026-ALE-011/
56	[KEV] CVE-2026-76504 — Cisco Catalyst SD-WAN Manager : Cisco Catalyst SD-WAN Manager Hex Encoding Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-09-30	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-76504
57	[KEV] CVE-2026-102489 — Zammad GmbH Zammad : Zammad GmbH Zammad Session Fixation Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-02	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-102489
58	[KEV] CVE-2026-102490 — Zammad GmbH Zammad : Zammad GmbH Zammad Improper Privilege Management Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-02	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-102490
59	[KEV] CVE-2026-88779 — Citrix NetScaler : Citrix NetScaler Improper Restriction of Operations within the Bounds of a Mem	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-04	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-88779
60	[KEV] CVE-2026-102764 — BeyondTrust Remote Support : BeyondTrust Remote Support Authentication Bypass by Spoofing Vulner	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-16	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-102764
61	Managing identity source transition for AWS IAM Identity Center	AWS Security Blog	2026-10-20	2026-10-29	https://aws.amazon.com/blogs/security/managing-identity-source-transition-for-aws-iam-identity-center/
62	[KEV] CVE-2026-48356 — Adobe Commerce and Magento : Adobe Commerce and Magento Unrestricted Upload of File with Dangerou	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-27	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-48356
63	Attackers Exploit Second Cisco Firewall VPN Zero-Day Since August	SecurityWeek	2026-10-29	2026-10-29	https://www.securityweek.com/attackers-exploit-second-cisco-firewall-vpn-zero-day-since-august/
64	From help desk impersonation to AD CS abuse: Investigating ESC1 and ESC8 intrusion paths	Microsoft Security Blog	2026-10-30	2026-10-31	https://www.microsoft.com/en-us/security/blog/2026/10/30/help-desk-impersonation-ad-cs-abuse-investigating-esc1-esc8-intrusion-paths/

#	Titre	Source	Publication	Consultation	URL
65	Cisco Secure Email Gateway Arbitrary File Write Vulnerability	Cisco — Security Advisories	2026-10-14	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-esa-afw-zqYJkjxp?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Secure%20Email%20Gateway%20Arbitrary%20File%20Write%20Vulnerability%26vs_k=1
66	Cisco Expressway Series Remote Code Execution Vulnerability	Cisco — Security Advisories	2026-10-21	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-vcs-static-cred-hr7EWZ8t?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Expressway%20Series%20Remote%20Code%20Execution%20Vulnerability%26vs_k=1
67	Siemens Software Center	CISA — Cybersecurity Advisories	2026-10-22	2026-10-29	https://www.cisa.gov/news-events/ics-advisories/icsa-26-295-03
68	Threat Brief: NetScaler Zero Days CVE-2026-88771 and CVE-2026-88772 Exploited in the Wild (Updated September 30)	Palo Alto Networks — Unit 42	2026-09-30	2026-10-29	https://unit42.paloaltonetworks.com/netscaler-zero-days-exploited/
69	[KEV] CVE-2026-104286 — Fortinet FortiMail : Fortinet FortiMail Path Traversal Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-01	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-104286
70	[KEV] CVE-2026-96951 — Microsoft Windows : Microsoft Windows Command Injection Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-13	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-96951
71	[KEV] CVE-2026-0322 — Palo Alto Networks PAN-OS : Palo Alto Networks PAN-OS Code Injection Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-14	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-0322
72	[KEV] CVE-2026-76519 — Cisco Secure Email Gateway : Cisco Secure Email Gateway Relative Path Traversal Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-14	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-76519
73	[KEV] CVE-2025-61624 — Fortinet Multiple Products : Fortinet Multiple Products Path Traversal Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-16	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2025-61624
74	Beyond the patch: Protecting your NetScaler gateway against future vulnerabilities	Cloudflare Blog	2026-10-19	2026-10-29	https://blog.cloudflare.com/protect-your-netscaler-gateway/
75	[KEV] CVE-2026-110936 — Siemens Software Center : Siemens Software Center Uncontrolled Search Path Element Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-20	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-110936
76	[KEV] CVE-2026-96652 — Plex Media Server : Plex Media Server Server-Side Request Forgery (SSRF) Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-20	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-96652
77	[KEV] CVE-2026-96654 — Plex Media Server : Plex Media Server Improper Neutralization of Encoded URI Schemes in a Web Pag	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-20	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-96654
78	[KEV] CVE-2026-96655 — Plex Media Server : Plex Media Server Server-Side Request Forgery (SSRF) Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-20	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-96655

#	Titre	Source	Publication	Consultation	URL
79	[KEV] CVE-2026-96656 — Plex Media Server : Plex Media Server External Control of File Name or Path Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-20	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-96656
80	[KEV] CVE-2026-106931 — EG Secure Solutions SiteGuard Server Edition : EG Secure Solutions SiteGuard Server Edition OS C	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-20	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-106931
81	PHP2Shell core RCE vulnerability patches (CVE-2026-109618 and CVE-2026-109619)	Fortinet — PSIRT Advisories	2026-10-21	2026-10-29	https://fortiguard.fortinet.com/psirt/FG-IR-26-186
82	Critical security issue affecting PHP	NCSC (Royaume-Uni) — Publications	2026-10-21	2026-10-29	https://www.ncsc.gov.uk/news/critical-security-issue-affecting-php
83	Using AWS WAF to apply mitigations for PHP2Shell RCE vulnerabilities (CVE-2026-109618 and CVE-2026-109619)	AWS Security Blog	2026-10-22	2026-10-29	https://aws.amazon.com/blogs/security/using-aws-waf-to-apply-mitigations-for-php2shell-rce-vulnerabilities-cve-2026-109618-and-cve-2026-109619/
84	How CVE-2026-73570 turns a Zimbra log file into remote code execution	Elastic Security Labs	2026-10-23	2026-10-29	https://www.elastic.co/security-labs/threat-command/command-injection-zimbra-cve-2026-73570
85	[KEV] CVE-2026-114625 — Arista VeloCloud Orchestrator : Arista VeloCloud Orchestrator SQL Injection Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-23	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-114625
86	CISA Adds One Known Exploited Vulnerability to Catalog	CISA — Cybersecurity Advisories	2026-10-23	2026-10-29	https://www.cisa.gov/news-events/alerts/2026/10/23/cisa-adds-one-known-exploited-vulnerability-catalog-0
87	CISA Confirms Active Exploitation of Two PHP2Shell Flaws Enabling Remote Code Execution	The Hacker News	2026-10-27	2026-10-29	https://thehackernews.com/2026/10/cisa-confirms-active-exploitation-of.html
88	[KEV] CVE-2026-41709 — Broadcom VMware ESX : Broadcom VMWare ESX Insufficient Logging Vulnerability	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-28	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-41709
89	Multiples vulnérabilités dans Palo Alto Networks PAN-OS (28 octobre 2026)	CERT-FR — Avis de sécurité	2026-10-28	2026-10-29	https://www.cert.cyber.gouv.fr/avis/CERTFR-2026-AVI-1402/
90	Inside KeyDrift: Analyzing historical UAT-11473 activity on Cisco SD-WAN	Cisco Talos Intelligence	2026-10-28	2026-10-29	https://blog.talosintelligence.com/uat-11473-keydrift/
91	[KEV] CVE-2026-76418 — Cisco Secure Firewall ASA Software and Cisco Secure FTD Software : Cisco Secure Firewall ASA Soft	CISA — Known Exploited Vulnerabilities (KEV)	2026-10-29	2026-10-29	https://www.cisa.gov/known-exploited-vulnerabilities-catalog?search_api_fulltext=CVE-2026-76418
92	Hackers exploit Cisco SD-WAN flaw to deploy custom KeyDrift malware	BleepingComputer	2026-10-29	2026-10-29	https://www.bleepingcomputer.com/news/security/hackers-exploit-cisco-sd-wan-flaw-to-deploy-custom-keydrift-malware/
93	Chainalysis discloses data breach from "offensive agentic techniques"	BleepingComputer	2026-10-31	2026-10-31	https://www.bleepingcomputer.com/news/security/chainalysis-discloses-data-breach-from-offensive-agentic-techniques/
94	Widespread PHP Flaw May Cause Many Site Outages Today	Krebs on Security	2026-10-21	2026-10-29	https://krebsonsecurity.com/2026/10/widespread-php-flaw-may-cause-many-site-outages-today/
95	Multiples vulnérabilités dans les produits Apple (27 octobre 2026)	CERT-FR — Avis de sécurité	2026-10-27	2026-10-29	https://www.cert.cyber.gouv.fr/avis/CERTFR-2026-AVI-1387/
96	Apple Backports Fix for Exploited CoreGraphics Flaw to Older iPhones and iPads	The Hacker News	2026-10-27	2026-10-29	https://thehackernews.com/2026/10/apple-backports-fix-for-exploited.html
97	Vulnérabilité dans Samba (28 octobre 2026)	CERT-FR — Avis de sécurité	2026-10-28	2026-10-29	https://www.cert.cyber.gouv.fr/avis/CERTFR-2026-AVI-1400/

#	Titre	Source	Publication	Consultation	URL
98	CISA Adds Two Known Exploited Vulnerabilities to Catalog	CISA — Cybersecurity Advisories	2026-10-28	2026-10-29	https://www.cisa.gov/news-events/alerts/2026/10/28/cisa-adds-two-known-exploited-vulnerabilities-catalog
99	Cisco IOS XE Software Security Hardening Release: August 2026	Cisco — Security Advisories	2026-10-02	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-hardening-iosxe-V8NMuMZJ?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20IOS%20XE%20Software%20Security%20Hardening%20Release:%20August%202026%26vs_k=1
100	Cisco NX-OS Software Security Hardening Release: October 2026	Cisco — Security Advisories	2026-10-07	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-hardening-nxosw1-cWzSbtR?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20NX-OS%20Software%20Security%20Hardening%20Release:%20October%202026%26vs_k=1
101	Cisco Application Policy Infrastructure Controller Security Hardening Release: October 2026	Cisco — Security Advisories	2026-10-07	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-hardening-apic-UOXWtfh?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Application%20Policy%20Infrastructure%20Controller%20Security%20Hardening%20Release:%20October%202026%26vs_k=1
102	Cisco License (Smart Software Manager) On-Prem Security Hardening Release: October 2026	Cisco — Security Advisories	2026-10-07	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-hardening-ssm-Ph77wdhf?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20License%20(Smart%20Software%20Manager)%20On-Prem%20Security%20Hardening%20Release:%20October%202026%26vs_k=1
103	Dutch DPA fines Uber EUR 824 990 000 for unlawful automated decision-making and insufficient information on profiling	EDPB — Actualités	2026-10-08	2026-10-29	https://www.edpb.europa.eu/news/dutch-dpa-fines-uber-eur-824-990-000-for-unlawful-automated-decision-making-and-insufficient_en
104	Hellenic DPA decision on a data breach involving E.E.T.A.A. S.A. as processor for the Ministry of Social Cohesion and Fa	EDPB — Actualités	2026-10-08	2026-10-29	https://www.edpb.europa.eu/news/hellenic-dpa-decision-on-a-data-breach-involving-eetaa-sa-as-processor-for-the-ministry-of_en
105	Swedish DPA fines Miljödata i Karlskrona approximately EUR 160 000 for insufficient technical and organisational measure	EDPB — Actualités	2026-10-08	2026-10-29	https://www.edpb.europa.eu/news/swedish-dpa-fines-miljodata-i-karlskrona-approximately-eur-160-000-for-insufficient-technical_en
106	Italian DPA fines BBVA EUR 5 508 000 for failing to respect a customer’s objection to direct marketing	EDPB — Actualités	2026-10-09	2026-10-29	https://www.edpb.europa.eu/news/italian-dpa-fines-bbva-eur-5-508-000-for-failing-to-respect-a-customers-objection-to-direct_en
107	Italian DPA fines Emirates EUR 180 000 for infringements concerning passengers’ health data	EDPB — Actualités	2026-10-09	2026-10-29	https://www.edpb.europa.eu/news/italian-dpa-fines-emirates-eur-180-000-for-infringements-concerning-passengers-health-data_en
108	Italian DPA fines security company EUR 39 000 for violations concerning employees’ data	EDPB — Actualités	2026-10-09	2026-10-29	https://www.edpb.europa.eu/news/italian-dpa-fines-security-company-eur-39-000-for-violations-concerning-employees-data_en
109	Italian DPA fines IQVIA EUR 7 000 000 for unlawful processing of patients’ health data	EDPB — Actualités	2026-10-09	2026-10-29	https://www.edpb.europa.eu/news/italian-dpa-fines-iqvia-eur-7-000-000-for-unlawful-processing-of-patients-health-data_en

#	Titre	Source	Publication	Consultation	URL
110	EDPB publishes statement on the data protection challenges of smart glasses	EDPB — Actualités	2026-10-13	2026-10-29	https://www.edpb.europa.eu/news/edpb-publishes-statement-on-the-data-protection-challenges-of-smart-glasses_en
111	Le CEPD publie une déclaration sur les enjeux de protection des données liés aux lunettes connectées	CNIL — Actualités	2026-10-13	2026-10-29	https://www.cnil.fr/fr/cepd-declaration-lunettes-connectees
112	Clôture de l’injonction prononcée à l’encontre de GOOGLE	CNIL — Actualités	2026-10-14	2026-10-29	https://www.cnil.fr/fr/cloture-injonction-google
113	Cisco Secure Email Gateway and Secure Email and Web Manager Security Hardening Release: September 2026	Cisco — Security Advisories	2026-10-14	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-hardening-esa-dfCrfXkm?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Secure%20Email%20Gateway%20and%20Secure%20Email%20and%20Web%20Manager%20Security%20Hardening%20Release:%20September%202026%26vs_k=1
114	Cisco Meraki Security Hardening Release: October 2026	Cisco — Security Advisories	2026-10-15	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-hardening-meraki-os-drbEX9GH?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Meraki%20Security%20Hardening%20Release:%20October%202026%26vs_k=1
115	Norwegian DPA fines Xandr EUR 8 600 000 for unlawful processing of personal data	EDPB — Actualités	2026-10-16	2026-10-29	https://www.edpb.europa.eu/news/norwegian-dpa-fines-xandr-eur-8-600-000-for-unlawful-processing-of-personal-data_en
116	Reconstitution d’adresses électroniques professionnelles : quels sont vos droits ?	CNIL — Actualités	2026-10-16	2026-10-29	https://www.cnil.fr/fr/reconstitution-adresses-professionnelles-vos-droits
117	Reconstitution d’adresses électroniques professionnelles : dans quel cadre est-ce autorisé ?	CNIL — Actualités	2026-10-16	2026-10-29	https://www.cnil.fr/fr/reconstitution-adresses-professionnelles-quel-cadre
118	De la protection des données à la création de valeur en finance : des autorités européennes publient une étude et des bo	CNIL — Actualités	2026-10-16	2026-10-29	https://www.cnil.fr/fr/protection-donnees-valeur-finance-etude-autorites-europeennes
119	Journée RGPD à Poitiers : cybersécurité, IA et conformité au cœur des enjeux de protection des données	CNIL — Actualités	2026-10-20	2026-10-29	https://www.cnil.fr/fr/journee-rgpd-2026-poitiers
120	CISA, FBI and Partners Warn Organizations of SafePay Ransomware Actors Targeting Multiple Critical Infrastructure Sector	CISA — Actualités	2026-10-21	2026-10-29	https://www.cisa.gov/news-events/news/cisa-fbi-and-partners-warn-organizations-safepay-ransomware-actors-targeting-multiple-critical
121	AlerteCyber : Failles de sécurité critiques dans PHP	Cybermalveillance.gouv.fr — Actualités	2026-10-22	2026-10-29	https://www.cybermalveillance.gouv.fr/tous-nos-contenus/actualites/alerte-cyber-failles-de-securite-critiques-dans-php-202610
122	Managing AI Token Consumption for Operational Resilience	CISA — Cybersecurity Advisories	2026-10-22	2026-10-29	https://www.cisa.gov/resources-tools/resources/managing-ai-token-consumption-operational-resilience
123	USN-8952-1: Tornado vulnerabilities	Ubuntu — Security Notices	2026-10-22	2026-10-29	https://ubuntu.com/security/notices/USN-8952-1
124	Multiple Cisco Products Snort 3 Security Hardening Release: October 2026	Cisco — Security Advisories	2026-10-22	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-hardening-snort3-ybgmhTQe?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Multiple%20Cisco%20Products%20Snort%203%20Security%20Hardening%20Release:%20October%202026%26vs_k=1

#	Titre	Source	Publication	Consultation	URL
125	CISA Adds One Known Exploited Vulnerability to Catalog	CISA — Cybersecurity Advisories	2026-10-23	2026-10-29	https://www.cisa.gov/news-events/alerts/2026/10/23/cisa-adds-one-known-exploited-vulnerability-catalog
126	⚡ Weekly Recap: This2Shell, That2Shell, Everything's an RCE? Rogue AI, Supply Chain Chaos and More	The Hacker News	2026-10-26	2026-10-29	https://thehackernews.com/2026/10/weekly-recap-this2shell-that2shell.html
127	Cisco Unified Communications Products Security Hardening Release: October 2026	Cisco — Security Advisories	2026-10-27	2026-10-29	https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-voice-hardening-twgbH9e3?vs_f=Cisco%20Security%20Advisory%26vs_cat=Security%20Intelligence%26vs_type=RSS%26vs_p=Cisco%20Unified%20Communications%20Products%20Security%20Hardening%20Release:%20October%202026%26vs_k=1
128	Chromium: CVE-2026-79260 Improper input validation in Cookies	Microsoft — Security Update Guide	2026-10-28	2026-10-29	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-79260
129	Sony ISP subsidiary data breach exposes 2.5 million customer records	BleepingComputer	2026-10-28	2026-10-29	https://www.bleepingcomputer.com/news/security/sony-isp-subsidiary-data-breach-exposes-25-million-customer-records/
130	Vulnérabilité dans les produits Cisco (29 octobre 2026)	CERT-FR — Avis de sécurité	2026-10-29	2026-10-29	https://www.cert.cyber.gouv.fr/avis/CERTFR-2026-AVI-1412/
131	China-Linked Hackers Exploited VMware ESX Zero-Day to Reduce Audit Trail Visibility	The Hacker News	2026-10-29	2026-10-29	https://thehackernews.com/2026/10/china-linked-hackers-exploited-vmware.html
132	Cisco Patches Actively Exploited ASA and FTD VPN Flaw That Can Crash Firewalls	The Hacker News	2026-10-29	2026-10-29	https://thehackernews.com/2026/10/cisco-patches-actively-exploited-asa.html
133	Cookies et application mobile : sanctions de 7 millions d’euros à l’encontre des sociétés FNAC DARTY PARTICIPATIONS ET S	CNIL — Actualités	2026-10-29	2026-10-29	https://www.cnil.fr/fr/sanction-cookies-app-fnac
134	ThreatsDay: Critical Firewall Flaws, Banking Trojans Rented, Weaponized PDF, Token Theft + 26 More Stories	The Hacker News	2026-10-29	2026-10-29	https://thehackernews.com/2026/10/threatsday-critical-firewall-flaws.html
135	Japan Airlines suffers third-party data breach exposing passenger info	BleepingComputer	2026-10-29	2026-10-31	https://www.bleepingcomputer.com/news/security/japan-airlines-suffers-third-party-data-breach-exposing-passenger-info/
136	Drupal Commerce Core Vulnerability Exploited Against Online Stores	SecurityWeek	2026-10-30	2026-10-31	https://www.securityweek.com/drupal-commerce-core-vulnerability-exploited-against-online-stores/
137	VAPOR PANDA Uses AI-Driven ARTEX to Scale a Global Espionage Campaign	CrowdStrike Blog	n.c.	2026-10-31	https://www.crowdstrike.com/en-us/blog/vapor-panda-uses-artex-to-scale-global-campaign/
138	Evolution of Web3 in Cloud Supply Chain Attacks	Palo Alto Networks — Unit 42	2026-10-07	2026-10-29	https://unit42.paloaltonetworks.com/web3-cloud-supply-chain-attacks/
139	“Next Exploit Opportunities”: How a Threat Actor Used AI to Help Plan and Execute Multiple Types of Cybercrime Activitie	Palo Alto Networks — Unit 42	2026-10-21	2026-10-29	https://unit42.paloaltonetworks.com/ai-assisted-cybercrime-analysis/
140	Inside the LiteLLM 1.107.0 supply chain compromise: Credential theft through Python startup hooks	Microsoft Security Blog	2026-10-23	2026-10-29	https://www.microsoft.com/en-us/security/blog/2026/10/23/inside-the-litellm-1-107-0-supply-chain-compromise-credential-theft-through-python-startup-hooks/
141	AI-Generated Fake Login Pages Are Making Account Takeovers Easier	The Hacker News	2026-10-27	2026-10-29	https://thehackernews.com/2026/10/ai-generated-fake-login-pages-are.html
142	American Organizations Under Attack: Skyw4lker Device Code Phishing Campaign Exposed	The Hacker News	2026-10-28	2026-10-29	https://thehackernews.com/2026/10/american-organizations-under-attack.html

#	Titre	Source	Publication	Consultation	URL
143	In Other News: Anthropic Breach Dispute, UEFI Flaw Hits Most Servers, Cloudflare AI Data Leak	SecurityWeek	2026-10-30	2026-10-31	https://www.securityweek.com/in-other-news-anthropic-breach-dispute-uefi-flaw-hits-most-servers-cloudflare-ai-data-leak/
144	Appraisal by AI: Model-driven victim prioritization in the VOLTA infostealer	Cisco Talos Intelligence	2026-10-31	2026-10-31	https://blog.talosintelligence.com/appraisal-by-ai-model-driven-victim-prioritization-in-the-volta-infostealer/
145	DSA-6575-1 nginx - security update	Debian — Security Advisories (DSA)	2026-10-21	2026-10-29	https://lists.debian.org/debian-security-announce/2026/msg00490.html
146	First harmonised standard supporting the AI Act published in the Official Journal	Commission européenne — Stratégie numérique (filtrée)	2026-10-19	2026-10-29	https://digital-strategy.ec.europa.eu/en/library/first-harmonised-standard-supporting-ai-act-published-official-journal
147	Localizing compliance at scale: achieving South Korea’s ISMS certification	Cloudflare Blog	2026-10-22	2026-10-29	https://blog.cloudflare.com/k-isms/
148	NIK C2: The new AI-enabled command-and-control framework	Cisco Talos Intelligence	2026-10-29	2026-10-29	https://blog.talosintelligence.com/nik-c2-new-ai-enabled-framework/
149	AWS Continuum sets a new standard in autonomous code security	AWS Security Blog	2026-10-05	2026-10-29	https://aws.amazon.com/blogs/security/aws-continuum-sets-a-new-standard-in-autonomous-code-security/
150	Introducing Privateer: AI-Assisted Security & Compliance Evaluation Framework Joins the OpenSSF Sandbox	OpenSSF — Blog	2026-10-13	2026-10-29	https://openssf.org/blog/2026/10/13/introducing-privateer-ai-assisted-security-compliance-evaluation-framework-joins-the-openssf-sandbox/
151	Design Tenets for Agent Identity Management Systems	NIST — Cybersecurity Insights (blog)	2026-10-27	2026-10-29	https://www.nist.gov/blogs/cybersecurity-insights/design-tenets-agent-identity-management-systems
152	New LF Research Survey Shows Generative AI Cuts Open Source Coding Time in Half, but 25% of Incoming Pull Requests are C	OpenSSF — Blog	2026-10-30	2026-10-31	https://openssf.org/press-release/2026/10/30/new-lf-research-survey-shows-generative-ai-cuts-open-source-coding-time-in-half-but-25-of-incoming-pull-requests-are-considered-ai-slop/
153	Securing Water and Wastewater Operational Technology Environments	NIST — Cybersecurity Insights (blog)	2026-10-01	2026-10-29	https://www.nist.gov/blogs/cybersecurity-insights/securing-water-and-wastewater-operational-technology-environments

Références officielles du référentiel réglementaire et normatif

Texte / norme	Référence	Sources officielles	Fiche révisée le
RGPD — Règlement général sur la protection des données	Règlement (UE) 2016/679	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679	2026-10-31
NIS 2 — Directive sur la sécurité des réseaux et des systèmes d'information	Directive (UE) 2022/2555 ; règlement d'exécution (UE) 2024/2690	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022L2555 https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32024R2690 https://monespacenis2.cyber.gouv.fr/ https://www.senat.fr/	2026-10-31
DORA — Résilience opérationnelle numérique du secteur financier	Règlement (UE) 2022/2554	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022R2554	2026-10-31
AI Act — Règlement européen sur l'intelligence artificielle	Règlement (UE) 2024/1689	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32024R1689 https://ai-act-service-desk.ec.europa.eu/	2026-10-31
CRA — Règlement sur la cyberrésilience	Règlement (UE) 2024/2847	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32024R2847	2026-10-31
eIDAS 2 — Identité numérique européenne et services de confiance	Règlement (UE) 2024/1183 modifiant le règlement (UE) n° 910/2014	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32024R1183	2026-10-31

Texte / norme	Référence	Sources officielles	Fiche révisée le
Dispositif OIV (loi de programmation militaire)	Code de la défense, art. L. 1332-6-1 et suivants	https://www.legifrance.gouv.fr/codes/section_lc/LEGITEXT000006071307/LEGISCTA000028344696/	2026-10-31
Certification Hébergeur de Données de Santé (HDS)	Code de la santé publique, art. L. 1111-8 ; référentiel de certification HDS	https://esante.gouv.fr/produits-services/hds	2026-10-31
PCI DSS — Sécurité des données de cartes de paiement	PCI DSS v4.0.1 (PCI Security Standards Council)	https://www.pcisecuritystandards.org/document_library/	2026-10-31
ISO/IEC 27001 — Systèmes de management de la sécurité de l'information	ISO/IEC 27001:2022 (+ Amd 1:2024)	https://www.iso.org/standard/27001	2026-10-31
ISO/IEC 27002 — Mesures de sécurité de l'information	ISO/IEC 27002:2022	https://www.iso.org/standard/75652.html	2026-10-31
ISO/IEC 42001 — Système de management de l'IA	ISO/IEC 42001:2023	https://www.iso.org/standard/81230.html	2026-10-31
NIST Cybersecurity Framework 2.0	NIST CSWP 29 (CSF 2.0)	https://www.nist.gov/cyberframework	2026-10-31
Guide d'hygiène informatique de l'ANSSI et recommandations ANSSI	ANSSI — Guide d'hygiène informatique (42 mesures) et guides techniques	https://cyber.gouv.fr/publications/guide-dhygiene-informatique	2026-10-31
SecNumCloud — Référentiel de qualification des prestataires cloud	Référentiel SecNumCloud (ANSSI)	https://cyber.gouv.fr/secnumcloud-pour-les-fournisseurs-de-services-cloud	2026-10-31
AirCyber — Référentiel de maturité cyber de la filière aéronautique	Programme AirCyber (BoostAeroSpace) — niveaux Bronze, Silver, Gold	https://boostaerospace.com/aircyber/	2026-10-31
EN 9100 — Management de la qualité (aéronautique, spatial, défense)	EN 9100:2018 (série 9100 de l'IAQG)	https://iaqg.org/	2026-10-31
Contrôle des exportations de biens à double usage	Règlement (UE) 2021/821	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32021R0821 https://www.entreprises.gouv.fr/	2026-10-31
Part-IS — Sécurité de l'information dans l'aviation (EASA)	Règlement délégué (UE) 2022/1645 et règlement d'exécution (UE) 2023/203	https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022R1645 https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32023R0203 https://www.easa.europa.eu/	2026-10-31